Unidad VI - Seguridad y Auditoría

Administración de Sistemas de Información

n1krov

27 de octubre de 2026

Índice

1. Control del Ambiente Informático. 3

2. Management Responsable de IS. 3

3. Manejo de la seguridad de los SI. 4

3.1. Identificación del riesgo. . . . 6
3.1.1. Definiciones. . . . 7
3.2. Análisis del riesgo. . . . 9
3.3. Manejo del riesgo. . . . 12
3.3.1. Controles y contramedidas. . . . 14
3.4. Recuperación ante el desastre. . . . 16
3.4.1. Evaluación de riesgos. . . . 17
3.4.2. Formulación de un Plan de Contingencias. . . . 17
3.4.3. Metodologías de recuperación. . . . 19
3.4.4. Técnicas de auditoría y funciones del auditor en la continuidad de las operaciones. 19
3.5. Política de seguridad 19
3.5.1. Definición de política. . . . 21
3.5.2. Ciclo de vida de una política. . . . 22
3.6. Clasificación y tipos de ataques contra sistemas de información. . . . 23

4. Auditoría. 24

4.1. Auditoría de sistemas/informática (Lardent) 25
4.1.1. Aspectos a revisar por la auditoría de sistemas (áreas) 26
4.2. Control interno. . . . 26
4.2.1. Categorías de controles (Lardent) 27
4.2.2. Implantación de un Sistema de Control Informático Interno (Piattini) 27
4.2.3. Auditoría informática vs. Control Interno Informático (Piattini) 28
4.3. Control interno informático (Piattini) 29
4.3.1. Similitudes y diferencias entre control interno informático y auditor informático interno. . . . 30
4.4. Etapas de la auditoría. . . . 30
4.5. Programa de revisión 31
4.6. **Pasos para la ejecución de una auditoría de sistemas de información.** 33
4.6.1. **Pasos para la ejecución de una auditoría de sistemas de información.** 34
4.6.2. Evaluación de riesgos globales. . . . 34
4.6.3. Desarrollo del programa de auditoría 35

4.7. La importancia de los procedimientos (Soria Ojeda) . . . 37
4.8. Evidencia en la auditoría. . . . 37
4.9. Tipos de pruebas . . . 38
4.10. Objetos (secciones de la auditoría de sistemas) . . . 38
4.11. Deontología (reglas éticas) del auditor . . . 38
4.12. Auditoría interna . . . 39
4.13. **Auditoría externa** . . . 39
4.14. Comparación entre el control interno, auditoría interna y externa informática. . . . 40
4.15. Informes de auditoría. . . . 41
4.15.1. Estructura básica de un informe de auditoría (Lardent) . . . 41
4.15.2. Tipos de informes (Lardent) . . . 42
4.16. Auditoría de la Función Informática (Auditoría de Organización y Administración del Ambiente Informático) . . . 42
4.17. Auditoría del Desarrollo de Sistemas. . . . 43
4.18. Auditoría de Sistemas de Aplicación Instalados . . . 45
4.19. Auditoría de Seguridad . . . 46
4.19.1. Técnicas de evaluación y auditoría . . . 46
4.19.2. Cómo se hace el plan de auditoría . . . 47

5. Extras **59**
5.1. Cuestionario Parte I - Seguridad de SI/TI. . . . 59
5.2. Parte II. Auditoría de SI/TI. . . . 59

1. Control del Ambiente Informático.

Es el conjunto conformado por la **seguridad, la auditoría y los controles** aplicados sobre el área del SI y sus recursos, así como sobre todos los sectores asociados al procesamiento de información de la organización.

El **ambiente informático** involucra no solo el correspondiente al departamento de procesamiento de datos sino también **a todos aquellos sectores de la organización que estén asociados con aquel**, ya sea porque son proveedores de datos a procesar o porque son usuarios de información procesada, o bien procesan información localmente y proveen datos de resumen al procesador central.

Se controla el ambiente informático como medida de **prevención de riesgos**, a manera de evitar posibles pérdidas para la organización. Además, se debe controlar que todas las actividades se efectúan de acuerdo con los procedimientos y normas fijados, así como comprobar el logro de los niveles de servicio adecuados.

Los **procesos de control del ambiente informático** son las herramientas que garantizan que las tecnologías y áreas relacionadas al procesamiento de la información funcionen adecuadamente. Cualquier punto en donde se tiene un procesamiento de información, aunque sea en papel, tiene que cumplir con las pautas de estos procesos de control.

Los procesos de control del ambiente informático son la **gestión de la seguridad de los SI/TI y la auditoría de los SI/TI.**

2. Management Responsable de IS.

Robson - Capítulo 13.

La gestión o management de la seguridad del ambiente informático consiste en la administración de los SI/TI de un "modo seguro". Cuando nos referimos a los IS seguros nos referimos a los siguientes aspectos:

¿Qué cuestiones determinan el management de los SI de un modo "seguro"?

1. "Seguros" desde un punto de vista organizacional, es decir, **técnico**.
   Acá se usan herramientas. Las fuentes de datos (formularios) y procedimientos internos están en este aspecto.
2. "Seguros" desde un punto de vista social, es decir, **ético**.
3. "Seguros" desde un punto de vista judicial, es decir, **legal**.
   ¿Cómo son los requisitos legales para ciertos procedimientos? Es un ejemplo de este aspecto.

El entorno organizacional se debe pensar y diseñar para que todo siga siendo seguro.

Estos tres puntos —el ético, el legal y el que hace a la seguridad— se superponen. Es frecuente que existan obligaciones legales y morales en relación con la seguridad de la información y su almacenamiento, procesamiento y recuperación. El marco legislativo actual de los SI codifica una perspectiva social de

lo que es correcto, es decir, de la ética. Mantener la seguridad de los SI puede plantear dilemas legales y éticos.

3. Manejo de la seguridad de los SI.

Se procederá al análisis desde el punto de vista técnico.

La gestión de la seguridad del ambiente informático implica gestionar los recursos SI/TI de un modo responsable.

> **¿Qué es la pérdida de seguridad? Cuando esta ocurre, ¿cuáles son los aspectos involucrados?**

Este aspecto se refiere a la visualización y el management de los riesgos en términos de las causas, los efectos y, por tanto, los costos que implica una **pérdida de seguridad**. Esta puede definirse como: "***la falla de los elementos de un sistema de información computarizado para realizar la función o brindar el o los servicios para los cuales estaba destinado***".

Dicha falla es una pérdida de uno o más de los siguientes **tres aspectos** desde el punto de vista técnico (o de todos):

1. Integridad de la información: La pérdida de seguridad destruye la capacidad de una empresa para confiar en sus datos, o peor, de contar con datos de precisión incierta.
2. Operatividad/disponibilidad: La pérdida de la seguridad destruye, total o parcialmente, la habilidad de la empresa para acceder a datos e información.
3. Confidencialidad: la pérdida de seguridad destruye la posesión exclusiva de datos, lo que provoca que la organización pierda poder y confianza. También involucra acceder a la información que al rol le corresponde desde sus responsabilidades organizacionales.

La pérdida de un aspecto puede impactar en otros aspectos.

> **¿Qué es la administración del riesgo? ¿Cómo se relaciona con la seguridad este concepto?**

De esta definición se desprende la noción de que las organizaciones necesitan **administrar el riesgo** de exposición de cada uno de los elementos de los IS. **Este management deberá considerar el equilibrio entre los costos resultantes de una falla de seguridad y los costos resultantes de las medidas necesarias para aumentar la seguridad**. El punto central es identificar el equilibrio óptimo.

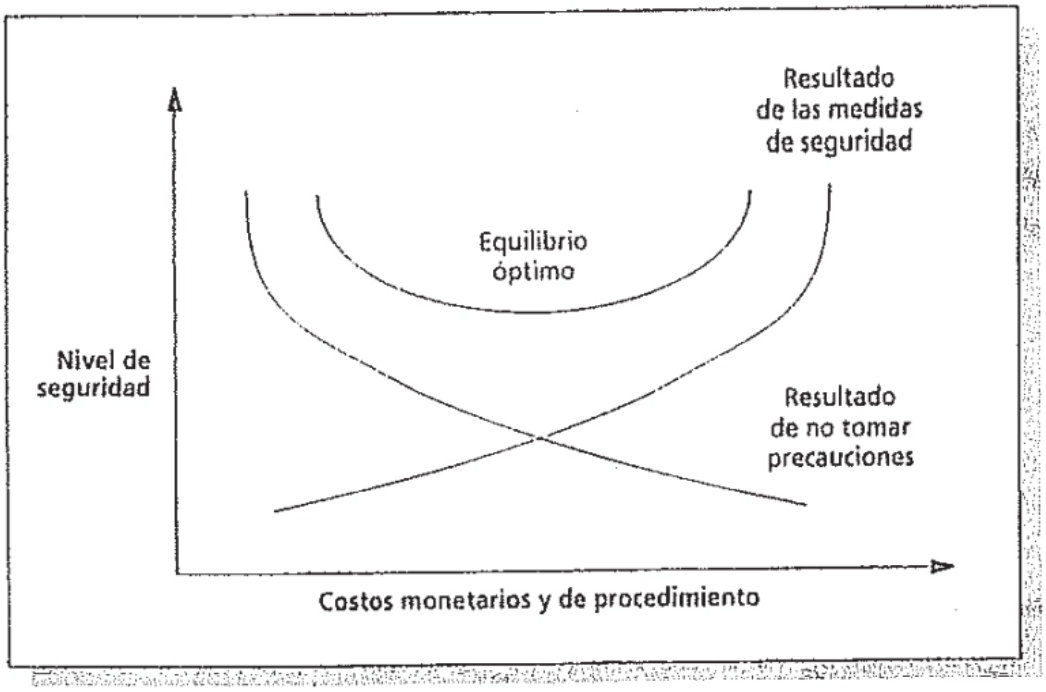


Figura 13.1. El equilibrio de los costos de seguridad.

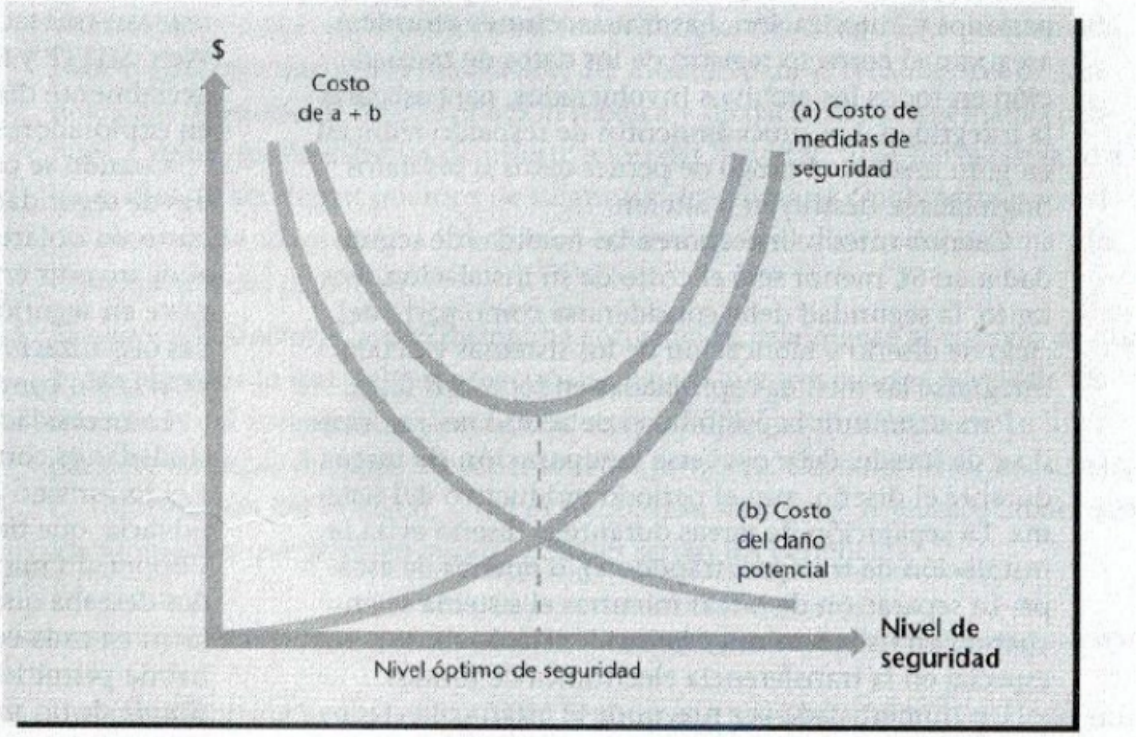


Figura 17.14 *El costo total para la empresa es más bajo en el punto "óptimo". No debe gastarse ni menos ni más en medidas de seguridad de información*

El costo de no tener seguridad puede ser difícil de definir, aun cuando las fallas ocurran. El management

del riesgo intenta reducir estas pérdidas. **Un enfoque sistemático del management del riesgo permitirá que los IS de seguridad sean administrados de forma tal que reconozcan la vulnerabilidad y la sensibilidad de los sistemas de la empresa, y los datos que estos contienen, pero también los costos de los controles y las medidas para el manejo de riesgos. Ningún sistema puede ser completamente seguro**. El management permite elegir e implementar las contramedidas de una forma planeada y administrada.

No se administra la seguridad en sí sino el nivel de riesgo. Menos nivel de riesgo tengo, más seguridad tengo. Se ven y evalúan medidas sobre el riesgo.

Premisas

- ***La seguridad total es imposible***. NUNCA se alcanza el 100% de seguridad. Solo se logra un nivel razonable.
- ***Mejor manejo de riesgo***. Busca el equilibrio entre los costos resultantes de una falla y los costos resultantes de las medidas necesarias para aumentar la seguridad.

El management de seguridad de SI se reduce a una metodología de **4 pasos genéricos**:

- Identificación del riesgo.
- Análisis del riesgo.
- Manejo del riesgo.
- Recuperación del desastre.

> **Enumerar y sintetizar las etapas de la administración del riesgo. → Están enumeradas arriba pero la explicación de cada una está abajo.**

3.1. Identificación del riesgo.

El primer paso es identificar "todos" los riesgos a los que es vulnerable un sistema particular, un conjunto de sistemas, una función o una empresa. Para realizar esta tarea, se necesitan dos cosas: **un conocimiento bastante detallado del trabajo de la organización**, más un **reconocimiento de las áreas que tienden a la vulnerabilidad**. Esta segunda parte, es decir, la comprensión del riesgo probable puede llevarse a cabo a través de consultores externos, pero la identificación de las amenazas específicas se realiza probablemente mejor mediante el personal o los consultores internos. ***Los consultores externos ofrecen un amplio conocimiento, mientras que el personal interno ofrece una profunda comprensión de la empresa***.

Se trata de encontrar los puntos débiles, es decir, todo aquello a lo que está potencialmente expuesto el ambiente informático. Se debe identificar, ***en ORDEN***:

- **Activos** a proteger que son vulnerables a la pérdida.
- Ubicación de los riesgos (¿dónde están?) y **vulnerabilidades** potenciales (¿cuáles tienen?).
- Fuentes de **amenazas** potenciales.

Â»

Yo puedo poner esto en una oración: tengo este ***activo*** con esta ***vulnerabilidad*** que como consecuencia puede poseer esta ***amenaza***.

3.1.1. Definiciones.

Amenaza: **condición del entorno del sistema de información** (persona, máquina, suceso o idea) **que, dada una oportunidad, podría dar lugar a que se produjese una violación de seguridad** (confidencialidad, integridad, disponibilidad, autenticidad, no repudio). **Es algo con capacidad de daño**. Un **ataque** es la realización de una amenaza.

Las amenazas pueden afectar a la disponibilidad (interrupción), la integridad (modificación), o la confidencialidad (intercepción).

Existen distintos **tipos de amenazas**:

- Físicas o lógicas.
- Accidental o deliberada.

La vulnerabilidad de un área en particular es dependiente de los siguientes factores:

- El personal de la organización.
- El tamaño de la red.
- La calidad de la transmisión de datos.



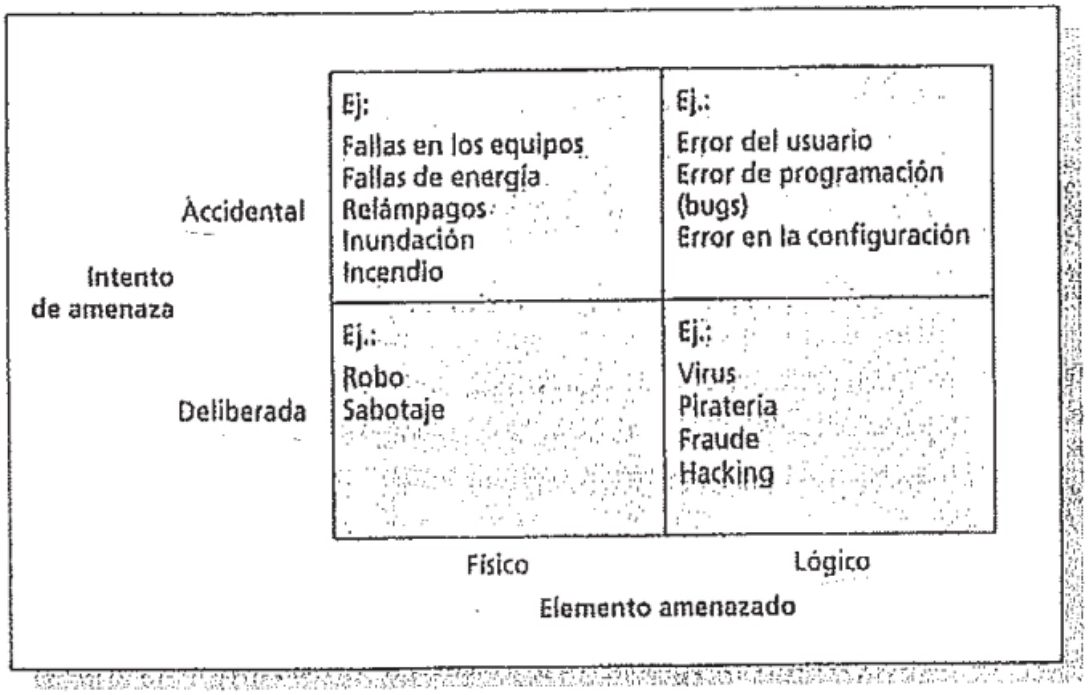


Figura 13.3. Lista de identificación de amenazas.

Los activos vulnerables a pérdidas debido a una amenaza pueden ser:

- Hardware: pérdida relativamente fácil de evaluar y estos elementos están a menudo asegurados.
- Software: la principal complicación cuando se evalúa la pérdida de software es que el valor intrínseco o costo de reemplazo del software no tiene relación con el costo original de desarrollo. Para sumar complicaciones, la pérdida de software genera una pérdida de la capacidad de procesamiento y, entonces, el factor debe incluirse en la cuantificación de pérdida del software.
- Datos e información: es la pérdida más seria y la más difícil de cuantificar.
- Capacidad de procesamiento: la duración de la interrupción es la variable clave al determinar el valor de la pérdida.
- Personal: esta pérdida puede ser significativa ya sea por su conocimiento teórico o por su competencia práctica.
- Fondos.

Riesgo: es el potencial de que una amenaza determinada explote las vulnerabilidades de un activo o de un grupo de activos, ocasionando su pérdida o daño (ISACA).

El concepto de riesgo está relacionado con el de materialidad, que se refiere a la magnitud del error en términos del impacto potencial para el conjunto de la organización. En general esa materialidad es expresada en términos monetarios.

Elementos del riesgo:

- Activos: información, datos, hardware, software, servicios, documentos, personal, etc.
- Amenazas: son el resultado de un análisis de vulnerabilidades: errores, ataque malicioso, fraude, robo, fallas de equipos, fallas de software.

- Vulnerabilidades: lo que es atacable: falta de conocimientos del usuario, falta de funcionalidad de la seguridad, mala elección de las contraseñas, tecnología no probada, transmisiones no seguras, etc.
- Impactos: son las pérdidas consecuentes de la ocurrencia de una amenaza: pérdida directa de dinero, violación de las leyes, pérdida de reputación, violación de la confianza, pérdida de oportunidad de negocio, reducción de la eficiencia, interrupción de las actividades del negocio.
- Riesgo Global: Una vez que los elementos del riesgo se establecen, se combinan para formar el carácter global del riesgo (cálculo del impacto de probabilidad para cada amenaza).
- Riesgo Residual: es el nivel de riesgo restante una vez que se han aplicado los controles. Puede ser utilizado por la gerencia para identificar las áreas en que se requiere más control para reducir aún más los riesgos, o bien para identificar puntos de control que estén siendo sobrecontrolados.

3.2. Análisis del riesgo.

> Una vez identificados los riesgos, se debe cuantificar la probabilidad y frecuencia esperada de ocurrencia de cada uno.

Ahora tengo que relacionar activos, vulnerabilidades, lugares en que se produce para poder formularlo, expresarlo y calcularlo. Acá le pongo valor monetario por si esto ocurre.

Una vez detectadas las amenazas, se puede proceder con el análisis de su **impacto potencial**. Si la etapa de identificación constituye una forma de "pensamiento creativo y espontáneo", entonces la etapa de análisis del riesgo es un proceso más estructurado, aunque a menudo de una manera cualitativa y no cuantitativa. **Consiste en analizar el impacto potencial, para determinar la pérdida esperada producida por una amenaza particular**. El análisis debe evaluar la pérdida esperada, producida por una amenaza en particular, en donde:

$$\text{Pérdida esperada} = \text{Pérdida potencial (\$)} \times \text{Frecuencia de pérdida}$$

Donde:

$$\text{Frecuencia de pérdida} = \text{Probabilidad de agresión} \times \text{Probabilidad de éxito (del ataque)}$$

El análisis del impacto potencial (es decir, por cada riesgo identificado, la probabilidad de ocurrencia y la gravedad de sus consecuencias) requiere de **dos etapas**. La primera evalúa los costos empresariales que surgen de una brecha en la seguridad. Esta evaluación debería incluir, al menos de un modo aproximado, cálculos financieros incluso para los costos conceptuales. Existe un gran número de aspectos relacionados con las pérdidas potenciales provenientes de una falla de seguridad.

A esto se le suma la posibilidad calculada de que suceda y entonces la segunda etapa del análisis de riesgo consiste en estimar la frecuencia de ocurrencia de cualquier falla de seguridad a través de la probabilidad de agresión y la probabilidad de que la agresión prospere (se entiende por agresión a cualquier falla en la seguridad, no necesariamente a un deliberado abuso humano).

Amenaza	Probabilidad de agresión		× Probabilidad de éxito		= Frecuencia
Entrada de datos incorrecta	muy alta	90%	mediana	50%	45%
Incendio	mediana	50%	alta	70%	35%
Hacking	baja	20%	mediana	50%	10%

Nota: la reducción del riesgo discutida en la Sección 13.1.3 puede disminuir la probabilidad de agresión o la probabilidad de éxito a fin de reducir la frecuencia; puede también reducir los costos resultantes para disminuir la pérdida general.

Figura 13.6. Cálculos de frecuencia de amenazas.

El producto de costo y frecuencia da como resultado la pérdida anual esperada para cada amenaza:

Costo (de las consecuencias) × Frecuencia (de los cálculos) = Exposición anual de pérdidas

El análisis del riesgo establece un lado del punto de equilibrio óptimo entre el costo de pérdidas y el costo de medidas de seguridad. El manejo del riesgo identifica contramedidas posibles y luego elige el conjunto adecuado para ese trueque óptimo.

Un análisis de riesgo efectivo requiere una apreciación de la verdadera magnitud de las pérdidas resultantes de cada amenaza, lo cual es difícil de determinar. El management efectivo del riesgo también requiere una valoración realista de la posibilidad de que la amenaza se convierta en realidad.

Todas las pérdidas que resultan de una falla en la seguridad se relacionan con los atributos de valor agregado de la información y se las puede dividir en tres categorías:

1. **Pérdida de disponibilidad**: la pérdida de la seguridad destruye, total o parcialmente, la habilidad de la empresa para acceder a datos e información.
2. **Falla en la integridad/precisión**: la pérdida de seguridad destruye la capacidad de una empresa para confiar en sus datos, o peor, de contar con datos de precisión incierta.
3. **Pérdida de confidencialidad/seguridad:** la pérdida de seguridad destruye la posesión exclusiva de datos, lo que provoca que la organización pierda poder y confianza. Una vez más, el peor caso es el de incertidumbre.

Para evaluar la magnitud de la pérdida resultante de una falla en la seguridad se deben considerar las **pérdidas directas (o consecuencias primarias)**, es decir, aquellas cosas que se desprenden directamente, y por lo general en forma inmediata, de un problema en la seguridad.

Ejemplos de pérdida directa:

- Interrupción del procesamiento a corto o largo plazo.
- Corrupción de los registros de datos, que a menudo incluyen material de backup; el peor caso es cuando la corrupción no se detecta o cuando su alcance es incierto.
- Destrucción de los medios de almacenamiento.
- Uso de software no autorizado; en el mejor de los casos, atasca las redes y reduce la capacidad de procesamiento; en el peor de los casos, los sistemas se destruyen y los fondos son mal dirigidos.
- Revelación de información confidencial.
- Desaparición de equipos, datos o software; el robo o la piratería son difíciles de reconocer.
- Pérdida de los registros de contabilidad u otros; en el mejor de los casos, esto perjudica el análisis histórico; en el peor de los casos, significa el detenimiento de los recibos de efectivo.

Consecuencias primarias.

No todas las pérdidas empresariales representan el resultado directo de una falla en la seguridad. Las **pérdidas secundarias** (que surgen como consecuencia de las pérdidas primarias, y no de una falla en sí misma) revisten gran importancia en los cálculos de pérdidas.

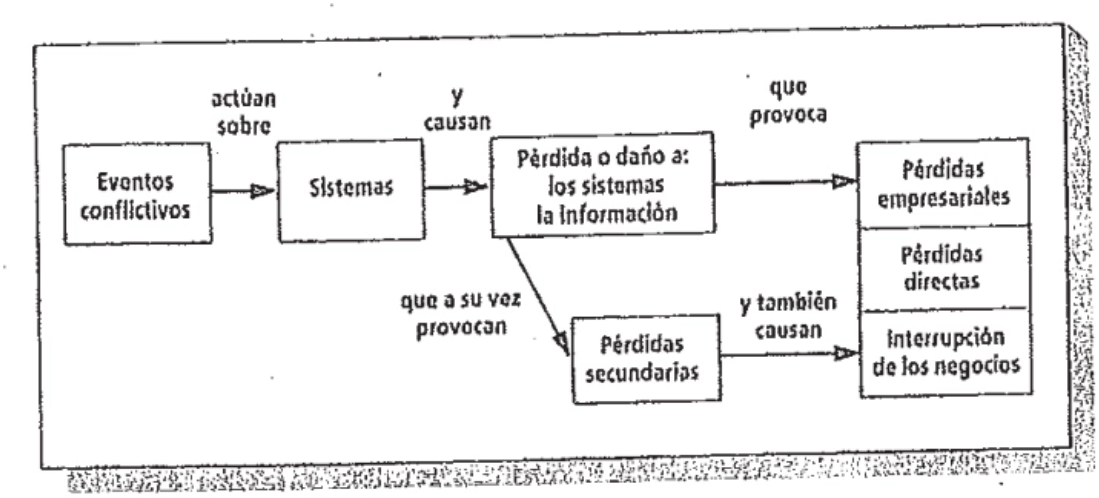


Figura 13.10. Pérdidas resultantes de una falla en la seguridad.

Si las consecuencias primarias son difíciles de cuantificar, es aún más difícil evaluar las consecuencias secundarias, que tienden a ser más costosas que las pérdidas directas y, como son costos empresariales, por lo general surgen después de un largo tiempo. Pocas veces resulta práctico vincular valores monetarios detallados a las consecuencias secundarias; se utilizan en cambio clasificaciones cualitativas.

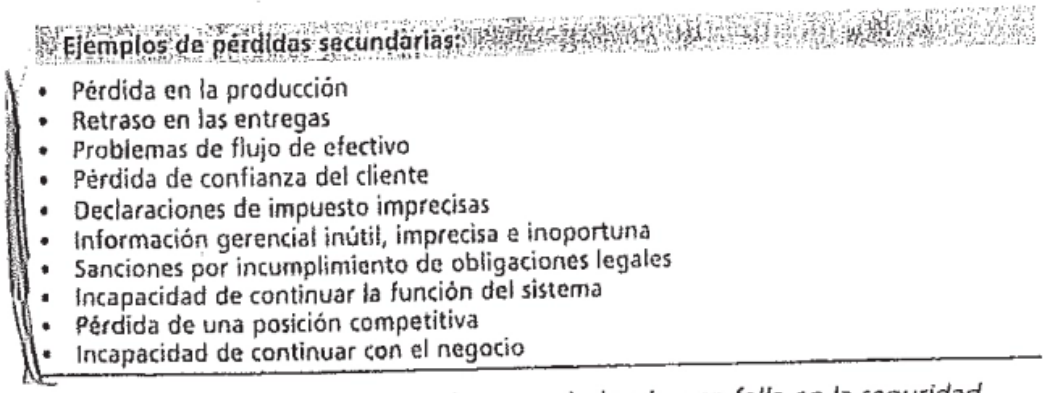


Figura 13.11. Consecuencias secundarias de una falla en la seguridad.

Consecuencias/pérdidas secundarias.

La magnitud de la pérdida total de una falla en la seguridad es la suma de las consecuencias primarias y secundarias. En el caso de que las consecuencias primarias puedan ser minimizadas, entonces habría una doble ganancia, porque si se reducen las pérdidas primarias, entonces las secundarias también se minimizan.

Ejemplos

Consecuencias Primarias	Consecuencias Secundarias
- Interrupción del procesamiento a corto o largo plazo	- Pérdida en la producción
- Corrupción de los registros de datos	- Retraso en las entregas
- Destrucción de los medios de almacenamiento	- Problemas de flujo de efectivo
- Uso de software no autorizado	- Pérdida de confianza del cliente
- Revelación de información confidencial	- Declaraciones de impuesto imprecisas
- Desaparición de equipos, datos o software	- Información gerencial inútil, imprecisa e inoportuna
- Pérdida de los registros de contabilidad u otros	- Sanciones por incumplimiento de obligaciones legales
	- Incapacidad de continuar la función del sistema
	- Pérdida de una posición competitiva
	- Incapacidad de continuar con el negocio

3.3. Manejo del riesgo.

> ***Una vez que tengo lo de la etapa 2, me sirve como insumo para saber qué estrategia de manejo de riesgo utilizo.***

La identificación y el análisis de las amenazas se realizan con el objetivo de implementar estrategias adecuadas que ofrezcan la mejor **efectividad** neta, es decir, que mantengan el equilibrio deseado. **Cualquier medida es más barata que perder los datos**.

El manejo del riesgo consiste en la aplicación de **controles y contramedidas** apropiadas para el riesgo, de acuerdo con el tiempo, el dinero y otras restricciones. Los pasos previos de:

1. Enumeración de amenazas potenciales.
2. Cuantificación de pérdidas que surgen como consecuencia de las amenazas exitosas.
3. Determinación de ALE (Tabla de pérdida anual) o alguna otra medida de probabilidad o gravedad de ocurrencia.

Constituyen un proceso valioso, pero solo como un medio para alcanzar un fin. El propósito es identificar el "mejor" método de manejo del riesgo, en donde "mejor" se define como un management de fallas potenciales de seguridad que sea efectivo en cuanto al costo. Existen cuatro **estrategias genéricas para el manejo del riesgo**:

1. Prevenir el riesgo: son medidas para **intentar evitar la amenaza**. Por ejemplo: colocar los sistemas lejos de las áreas peligrosas, ubicar los datos delicados en áreas protegidas, no descentralizar, ANTIVIRUS, etc.
2. Asumir el riesgo: se utiliza cuando las pérdidas totales (suma de las consecuencias primarias y secundarias) son tolerables por la organización. Acá también se debe tener en cuenta la probabilidad de ocurrencia.

   Es cuando podemos afrontar la pérdida esperada de un activo.

3. Reducir el riesgo: resulta difícil evitar por completo el riesgo y a veces es inadecuado ignorarlo. Consiste en la introducción de controles y contramedidas para **reducir la probabilidad de ocurrencia y/o para reducir las pérdidas resultantes** de una falla en la seguridad. Backup.

   Controles que me permitan reducir las pérdidas.

4. Transferir el riesgo: **transfiere los costos resultantes de una falla en la seguridad a un tercero**, que en general implica pólizas de seguros o contratos de mantenimiento.

   Por cada riesgo pensar una sola estrategia, las estrategias suponen en qué voy a hacer más foco para mis inversiones de seguridad.

Â»

La transferencia de riesgo, por lo general a través de la contratación de un seguro, resulta apropiada para las amenazas de **alto costo y baja probabilidad**, donde la recuperación es casi imposible.

Identificar un portfolio de management de riesgo significa seleccionar un conjunto heterogéneo de estrategias de manejo del riesgo que dependen de la aplicación sistemática de la identificación y el análisis del riesgo.

Cada vez más, la seguridad de los SI debe ser considerada como un tema estratégico, y toda empresa debería invertir en seguridad. Si el resultado de las pérdidas prevenidas o reducidas es mayor que el costo de seguridad, entonces existe una contribución neta a las ganancias.

Una **política de seguridad** define el nivel de seguridad que se ajusta al valor de lo que se debe proteger y al gasto e inconveniencia de las medidas de protección. Esas políticas documentan el resultado de la identificación y el análisis del riesgo, y de las estrategias elegidas para manejarlo.
El documento debe cubrir al menos:

- La protección de la información: dado que la naturaleza de la información determina su atractivo externo y su importancia interna.
- El valor de la información: ya que cuantifica las pérdidas potenciales.
- El acceso a la información: porque define quién está autorizado para ver, modificar, cargar o bajar los datos.
- La recuperación de la información: porque define cómo los datos perdidos o dañados pueden recuperarse y luego utilizarse.

Tipos de políticas de seguridad:

Permisiva: expresa lo que particularmente está prohibido (da más libertad o mayor amparo, lo que no está expresamente prohibido está permitido).

Prohibitiva: lo que no está expresamente permitido, está prohibido (mucho más restringida).

3.3.1. Controles y contramedidas.

Las estrategias de manejo del riesgo se implementan a través de **controles y contramedidas**. La elección del conjunto que, de un modo efectivo con respecto al costo, evita, reduce o transfiere el impacto del riesgo, **es obviamente un aspecto del management del riesgo**. Las medidas de seguridad y control deben ser consideradas en términos de los costos netos y de los nuevos riesgos potenciales resultantes de su adopción.

Existen fundamentalmente dos tipos de control: las **contramedidas *(se introducen ante la ocurrencia de la amenaza)*** generales que se introducen para reducir la amenaza de todas las actividades de los SI dentro de una organización; y los **controles de aplicación** diseñados para proteger de amenazas a un área específica. Un punto débil en los controles generales podría provocar una pérdida de seguridad en cualquier sistema y así, el costo de estas medidas debería considerarse "compartido" por todas las áreas protegidas. Hasta cierto punto, los controles de aplicación son un conjunto de controles generales y para la mayoría de las empresas. Un punto débil en los controles generales podría provocar una pérdida de seguridad en cualquier sistema y así, el costo de estas medidas debería considerarse "compartido" por todas las áreas protegidas.

Controles: **Prevención y detección**, medidas implementadas antes de un incidente para reducir la probabilidad de que ocurra o para detectarlo tempranamente.

Contramedidas: Respuesta y mitigación, **medidas tomadas después de un incidente para limitar los daños** y recuperar la normalidad.

Los controles y las contramedidas no son un único conjunto homogéneo. Para dar como resultado una "buena" seguridad, las diversas amenazas deben ser combatidas por **capas de controles** dirigidos a diferentes aspectos del uso y management de los IS.

En el caso de los IS, la naturaleza precisa de las instancias de cada capa de control dependerá de:

- La plataforma de hardware: ejerce influencia en el tipo y la cantidad de controles disponibles.
- El grado de distribución: influye en el énfasis de los controles.
- La integración de la infraestructura: influye en la naturaleza de la amenaza.

Cualquier cambio en este entorno de los IS significa que las consecuencias de seguridad se extienden por todas las capas de control. Aun dentro de cada capa existen diferentes intenciones o etapas de control:

Primera línea de defensa	**Prevención**	Prevenir amenazas, evitar la ocurrencia de las amenazas. Por ejemplo: prohibir que se fume en el centro de datos.
Segunda línea de defensa	**Detección**	Detectar fallas de seguridad a pesar de la primera línea de defensa. Por ejemplo: un detector de humo. 'Si falla la primera línea, es decir, que ocurre el ataque, debo detectarlo'.
Tercera línea de defensa	**Recuperación**	Recuperarse de una falla de seguridad con pérdidas mínimas. Por ejemplo: backups de datos. 'Recuperarte al estado anterior a la amenaza'.

Estas tres etapas se aplican a la mayoría de las capas de control. Por ejemplo, el software de autorización puede tratar de prevenir el uso no autorizado, pero también registra los ingresos fallidos a fin de detectar los ataques y luego utiliza la encriptación de la segunda etapa para minimizar el daño causado por la entrada ilegal al sistema.

Las herramientas de seguridad son una de las contramedidas a implementar. También tengo políticas de seguridad, buenas prácticas de seguridad.

El **principal objetivo** cuando se seleccionan controles y contramedidas y, por lo tanto, cuando se define la política de seguridad, es **crear una situación equilibrada entre los costos de riesgo y los costos de control**.

Las contramedidas seleccionadas pueden ser lógicas o físicas. Los **controles lógicos** son las medidas adoptadas para asegurarse de que el desarrollo, la integridad de los datos y las operaciones continúen sin tropiezos. Una de las medidas de control lógico más común, y a menudo inadecuada, es la identificación del usuario y los sistemas de contraseñas para restringir el acceso a los sistemas. Las **medidas físicas** de seguridad generan más costos, son menos efectivas y más propensas a producir resentimiento y, por lo tanto, su uso debe ser cuidadosamente evaluado. Los controles físicos de seguridad pueden incluir el uso de personal de seguridad, sistemas de vigilancia, cerraduras, tarjetas con clave y otros métodos de acceso. Estas medidas filtran el acceso físico a la utilización de los elementos de IS.

Ejemplos de controles:

- Estándares de operatividad
- División de responsabilidades
- Medidas de seguridad de la red
- Contraseñas
- Encriptación de datos
- Antivirus
- Detección y prevención de incendios

3.4. Recuperación ante el desastre.

Este elemento asume que la prevención total del riesgo es poco práctica o imposible y que, por lo tanto, la empresa debe definir planes que permitan que la empresa sobreviva a algún tipo de desastre y de los procesos que permitan la recuperación. Esto se denomina **planificación de contingencias**, **e incluye planes para métodos de trabajo que permitan que la empresa sobreviva al desastre**, y para procesos a largo plazo a fin de que la organización se recupere. La primera etapa consiste en incrementar la seguridad, minimizar los daños y facilitar el regreso al trabajo. En la segunda etapa se minimizan los efectos secundarios del desastre. Los términos relacionados con estas etapas son:

- Tiempo de inhabilitación: cantidad de tiempo antes de que los sistemas vuelvan a estar disponibles para las operaciones.
- Respaldo: mantener el funcionamiento de la empresa a través de los sistemas claves (críticos y vitales) hasta que se vuelva a la normalidad.
- Reinstalación: sistemas de actualización con todos los datos generados durante el tiempo de inactividad de la sede central.

Por supuesto que el management de riesgo busca prevenir en los casos en que esto es posible, pero también debe prepararse para los desastres. La recuperación ante desastres debe llevarse a cabo con rapidez a fin de estar listo para cualquier falla en la prevención del riesgo y, de hecho, una estrategia de reducción del riesgo reconoce que existe la probabilidad residual de una falla en la seguridad. **En algunos casos, cuando las consecuencias del riesgo son bajas, la prevención no es mejor que la cura y, entonces, la recuperación en sí misma puede ser una estrategia adecuada para el manejo de riesgo**.

El primer paso de la planificación de contingencias consiste en clasificar los sistemas y aplicaciones de acuerdo con la necesidad de operaciones empresariales (***grado de tolerancia***). Esta clasificación permite establecer prioridades entre los elementos de los IS. El plan de recuperación debe cubrir todos los aspectos del uso y del management de los SI.

	CRÍTICOS	VITALES	SENSIBLES	NO CRÍTICOS
Tolerancia a la interrupción	Muy baja (Costo de interrupción muy alto)	Moderada (Costo de interrupción ligeramente menor)	Flexible (costos tolerables)	Amplia (Costo escaso o costo adicional nulo)
Reemplazo de funciones	No pueden ser reemplazadas por métodos manuales	Puede ejecutarse manualmente por períodos breves	Pueden realizarse en forma manual por períodos relativamente largos. Exige mano de obra adicional	Pueden reemplazarse con poco esfuerzo

Las organizaciones que disponen de un alto nivel de automatización están sometidas a mayores riesgos que aquellas escasamente mecanizadas y tendrán mayores dificultades para restaurar sus procedimientos, y además tendrán menor capacidad de procesar sus datos.

Como la planificación de contingencias es parte del management estratégico de los SI, no se la puede separar de otros aspectos de gerenciamiento del uso de los SI y debe ser considerada junto con otros temas de la selección y la implementación de estrategias.

Existen dos problemas importantes en la planificación ante desastres: la dificultad de mantenerse actualizado con los tiempos de desastre, y la dificultad de mantenerse actualizado con los cronogramas de prioridades.

Se deben tener backups y mantenerlos off-site para prevenir que los desastres posibles afecten a los mismos.

Las soluciones de respaldo (mantenimiento) pueden clasificarse en (disponibilidad de hardware alternativo en Lardent):

- **Instalaciones de emergencia**: en las que todo lo que posibilita el funcionamiento de IS ya está instalado; permiten una operatividad inmediata, siempre y cuando los backups de datos estén disponibles.
- **Instalaciones intermedias**: un centro de datos vacío pero equipado se encuentra disponible. Son menos costosas que el anterior pero su puesta en actividad es más lenta.
- **Instalaciones móviles**: la provisión se realiza desde vehículos o desde edificaciones prefabricadas semimóviles.

Todos los enfoques de desarrollo de los SI deben ofrecer puntos de recuperación.

3.4.1. Evaluación de riesgos.

Los riesgos que interesan en este ámbito son los vinculados con la probabilidad de presentación de un desastre. Un **desastre** es todo suceso sujeto a un cierto grado de incertidumbre en cuanto a su ocurrencia, pero que cuando ocurre tiene potencial como para interrumpir o afectar seriamente la operación normal de un negocio.

Los riesgos deben ser clasificados a efectos de priorizar las acciones, en conformidad con la sensibilidad al tiempo (necesario para que se reanude el negocio luego de la ocurrencia de un desastre). La evaluación del riesgo debe considerar la tolerancia del sistema; esto es, la capacidad de enfrentar una interrupción de los sistemas. La tolerancia puede ser expresada como un valor monetario.

3.4.2. Formulación de un Plan de Contingencias.

Definición de planes que permiten que la empresa sobreviva a algún tipo de desastre y de los procesos que permitan la recuperación. Se debe prever: tiempo de inhabilitación, respaldo o mantenimiento, reinstalación, tolerancia del sistema.

Se pueden diferenciar 3 tipos de situaciones de interrupción de las actividades:

1. **Catástrofe**: son interrupciones en la capacidad de procesamiento provocadas por la **destrucción de instalaciones y de los componentes físicos que las integran**. En estos casos se requiere acudir transitoriamente a otra instalación alternativa de configuración similar a la destruida. Simultáneamente debe equiparse una nueva instalación que, a muy corto plazo, tenga capacidad de procesamiento continuo del servicio de procesamiento de datos.
2. **Desastre**: Se trata de **interrupciones en la capacidad de procesamiento de información durante un periodo superior a un día**, pero con altas posibilidades de reanudar las mismas en la instalación original luego de superados los inconvenientes causantes de la interrupción. Se deberá recurrir a una instalación de procesamiento alternativa utilizando copias de software y de archivos de datos conservados fuera de la sede original.
3. **No desastres**: Se trata de **interrupciones breves que no duran más que un día**. Son provocadas por mal funcionamiento de algún dispositivo o por fallas en el software no detectadas anteriormente y que requieren inmediata corrección.

Todo sistema tiene un **lapso crítico de recuperación**. Este es el periodo o tiempo hasta donde puede extenderse una interrupción antes de que se presente el riesgo de incurrir en pérdidas. Es la naturaleza del negocio y de los sistemas lo que condiciona este lapso crítico.

La formulación del plan de contingencias es responsabilidad de la gerencia superior. El plan de contingencias contendrá lo siguiente:

- Determinación del orden de prioridades en materia de recuperación de aplicaciones, software de base y archivos de datos según el grado de tolerancia.
- Detalle del orden de procesamiento de tareas complejas.
- Mecanismos de acoplamiento manual durante interrupciones cortas.
- Tener en cuenta los equipos de todo el ambiente informático y no solo las unidades centrales. El personal debe ser entrenado. Sedes remotas.
- Disponibilidad de hardware alternativo: hay dos alternativas:
  - Centro duplicado de procesamiento de información de propiedad de la misma empresa (para aplicaciones críticas). Es eficaz pero costoso.
  - Centros de procesamiento ubicados en otra sede (por contratos con 3ros). En función del tiempo de activación y costos se pueden clasificar en:
    * Hot Sites: son instalaciones completas, configuradas de manera similar a la sede primaria y pueden activarse rápidamente.
    * Warm Sites: son instalaciones parcialmente configuradas en las que generalmente falta la unidad central de procesamiento. Dado que esta unidad es el dispositivo más costoso, esta alternativa es más económica.
    * Cold Sites: son lugares físicos que se encuentran en condiciones de recibir el equipamiento necesario, pero no disponen de instalaciones específicas.
- Disponibilidad de la capacidad de telecomunicaciones:
  - Rutas alternativas: se utiliza cuando se interrumpe la red normal.
  - Rutas diversificadas: alternativas en distinto lugar físico.
- Disponibilidad de una sede alternativa para el almacenamiento de medios magnéticos (datos de backup) y documentación.

3.4.3. Metodologías de recuperación.

Establece los pasos a seguir en las situaciones de emergencia.

- Protección de la vida humana.
- Evaluación de daños y estimación de tiempo necesario para la recuperación.
- Coordinación de las actividades de recuperación; recuperar datos vitales y críticos y reconstruir la base de datos; instalar y probar el software en una sede alternativa.
- Restauración del software base y de aplicación en la sede alternativa.
- Recuperación de la red de telecomunicaciones.
- Preparación de datos y registro, supervisar los trabajos de obtención de datos fuente y de su carga y actualización de la base de datos.
- Almacenamiento en sede alternativa, formular un cronograma y vigilar el cumplimiento de las actividades a desarrollar en sede alternativa para el almacenamiento de la información inicial y de la que se vaya generando durante el proceso de recuperación.
- Administración de condiciones de seguridad.
- Provisión de apoyo administrativo, tareas de control y balanceo de datos.
- Gestión de aspectos legales derivados de la emergencia.

3.4.4. Técnicas de auditoría y funciones del auditor en la continuidad de las operaciones.

La revisión de la continuidad de operaciones exige del auditor de SI la ejecución de las tareas que se indican a continuación:

- Evaluación del plan de contingencias, verificación de su adecuación y actualización y de su capacidad para permitir reiniciar el procesamiento de información luego de una interrupción imprevista. Verificación de que el plan considere desastres de diverso grado. Verificación de que para cada aplicación se haya determinado su nivel de tolerancia.
- Examen del inventario detallado de los elementos almacenados en la sede alternativa.
- Evaluación del grado de capacitación del personal a efectos de poder enfrentar con éxito la aplicación del plan de contingencias.
- Verificación de que el plan contemple mecanismos de fusión de los datos obtenidos o procesados durante el periodo de emergencia, con los existentes antes del desastre.
- Evaluación de las condiciones de seguridad física de la instalación alternativa, en cuanto a controles de acceso.
- Examen del contrato de procesamiento alternativo con el proveedor de la instalación.
- Evaluación de los resultados de pruebas anteriores.
- Análisis de la cobertura de seguros.

3.5. Política de seguridad

Apunte de la profe

El término se define generalmente como el conjunto de requisitos definidos por los responsables directos o indirectos de un sistema que indica, en términos generales, qué está permitido y qué no está permitido hacer en el área de seguridad durante la operación general de dicho sistema.

> ***Son medidas preventivas. Hay dos niveles, hay políticas generales y a estas las puedo especificar para cada activo, para cada perfil de usuario. Se usan en la primera medida de defensa.***

Una política es: los empleados de atención al cliente no pueden cambiar los estados, sino que el que lo hace es el jefe de sección.

Hay dos amplitudes de políticas:

- Políticas generales.
- Políticas específicas: para cada activo, para cada situación, para cada perfil de usuario.

Al tratarse de 'términos generales' aplicables a situaciones y recursos diversos, suele ser necesario refinar los requisitos de la política para convertirlos en indicaciones precisas de qué es lo que está permitido y lo denegado en cierta parte de la operación del sistema, lo que se **denomina política de aplicación específica**. Serían como reglas.

> El personal de atención al cliente no puede cambiar el estado de un cliente.

> **¿Cómo se clasifican las políticas de seguridad? ¿Cuáles son los tipos?**

Una política puede ser:

- Prohibitiva: si todo lo que no está expresamente permitido está denegado.
  - Esta es mucho más restrictiva y se podría considerar que son más efectivas en cuanto a seguridad se refiere.

    > Al área de TICS solo puede entrar el personal del área. A tal área solo pueden entrar tales personas.

- Permisiva: si todo lo que no está expresamente prohibido, está permitido.

  > ***No puedo tomar mate en el laboratorio, por ejemplo, pero entonces puedo tomar café, coca.***

Las políticas prohibitivas son más efectivas en cuanto a seguridad se refiere.

Cualquier política ha de contemplar seis elementos claves en la seguridad de un sistema informático:

- Disponibilidad: Es necesario garantizar que los recursos del sistema se encontrarán disponibles cuando se necesitan, especialmente la información crítica.
- Utilidad: Los recursos del sistema y la información manejada en el mismo han de ser útiles para alguna función.
- Integridad: La información del sistema ha de estar disponible tal y como se almacenó por un agente autorizado.
- Autenticidad: El sistema ha de ser capaz de verificar la identidad de sus usuarios, y los usuarios la del sistema.
- Confidencialidad: La información solo ha de estar disponible para agentes autorizados, especialmente su propietario.

- Posesión: Los propietarios de un sistema han de ser capaces de controlarlo en todo momento; perder este control en favor de un usuario malicioso compromete la seguridad del sistema hacia el resto de los usuarios.

3.5.1. Definición de política.

Política: Declaración general de principios que presenta la posición de la administración para un área de control definida. Las políticas se elaboran con el fin de que tengan aplicación a largo plazo y guíen el desarrollo de reglas y criterios más específicos que aborden situaciones concretas. Las políticas son desplegadas y soportadas por estándares, mejores prácticas, procedimientos y guías. Las políticas deben ser pocas (es decir, un número pequeño), deben ser apoyadas y aprobadas por las directivas de la universidad, y deben ofrecer direccionamientos a toda la organización o a un conjunto importante de dependencias. Por definición, las políticas son obligatorias y la incapacidad o imposibilidad para cumplir una política exige que se apruebe una excepción.

Estándar: Regla que especifica una acción o respuesta que se debe seguir a una situación dada. Los estándares son orientaciones obligatorias que buscan hacer cumplir las políticas. Los estándares sirven como especificaciones para la implementación de las políticas: son diseñados para promover la implementación de las políticas de alto nivel de la organización antes que crear nuevas políticas.

Mejor práctica: Es una regla de seguridad específica a una plataforma que es aceptada a través de la industria al proporcionar el enfoque más efectivo a una implementación de seguridad concreta. Las mejores prácticas son establecidas para asegurar que las características de seguridad de sistemas utilizados con regularidad estén configuradas y administradas de manera uniforme, garantizando un nivel consistente de seguridad a través de la organización.

Guía: Una guía es una declaración general utilizada para recomendar o sugerir un enfoque para implementar políticas, estándares y buenas prácticas. Las guías son, esencialmente, recomendaciones que deben considerarse al implementar la seguridad. Aunque no son obligatorias, serán seguidas a menos que existan argumentos documentados y aprobados para no hacerlo.

Procedimiento: Los procedimientos definen específicamente cómo las políticas, estándares, mejores prácticas y guías serán implementados en una situación dada. Los procedimientos son dependientes de la tecnología o de los procesos y se refieren a plataformas, aplicaciones o procesos específicos. Son utilizados para delinear los pasos que deben ser seguidos por una dependencia para implementar la seguridad relacionada a dicho proceso o sistema específico. Generalmente los procedimientos son desarrollados, implementados y supervisados por el dueño del proceso o del sistema. Los procedimientos seguirán las políticas de la organización, los estándares, las mejores prácticas y las guías tan cerca como les sea posible, y a la vez se ajustarán a los requerimientos procedimentales o técnicos establecidos dentro de la dependencia donde ellos se aplican.

Ejemplo

En el nivel más alto, se puede elaborar una **política**, para toda la organización, que obligue a ‘garantizar seguridad en el correo electrónico cuyo contenido sea información confidencial’.

Esta política podría ser soportada por varios **estándares**, incluyendo, por ejemplo, que los mensajes de este tipo sean enviados utilizando algún sistema de criptografía aprobado por la universidad y que sean borrados de manera segura después de su envío.

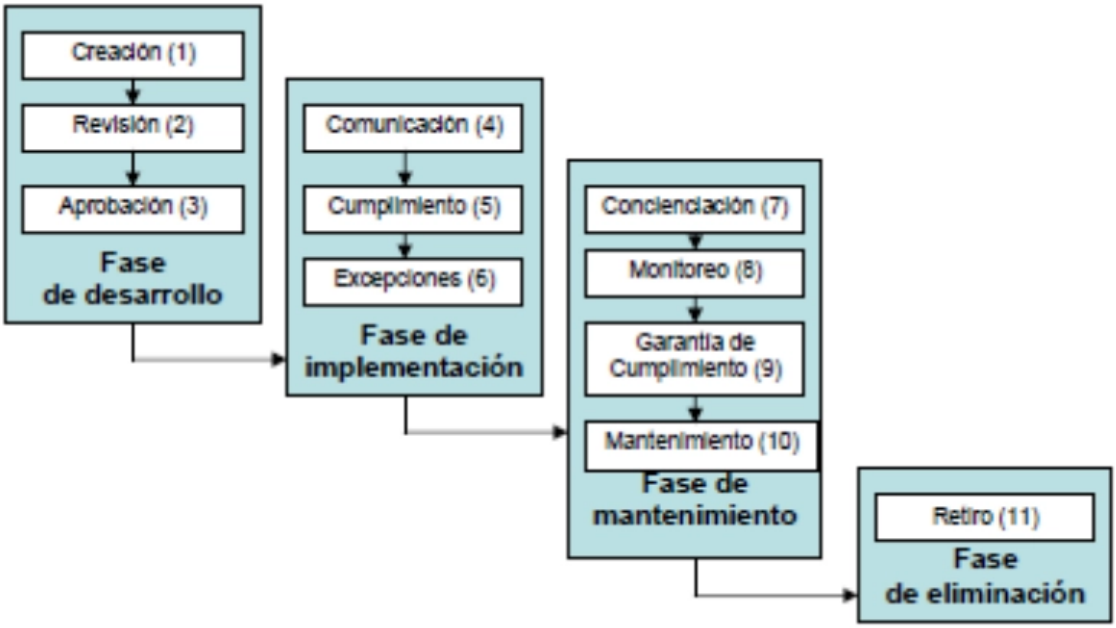
Una **mejor práctica**, en este ejemplo, podría estar relacionada sobre la manera de configurar el correo sobre un tipo específico de sistema (Windows o Linux) con el fin de garantizar el cumplimiento de la política y del estándar.

Los **procedimientos** podrían especificar requerimientos para que la política y los estándares que la soportan sean aplicados en una dependencia específica, por ejemplo, la Oficina de Control Interno.

Finalmente, las **guías** podrían incluir información sobre técnicas, configuraciones y secuencias de comandos recomendadas que deben seguir los usuarios para asegurar la información confidencial enviada y recibida a través del servicio de correo electrónico.

3.5.2. Ciclo de vida de una política.

1. **Fase de desarrollo**:
    1. Creación: se planifica, investiga y redacta una política. Implica identificar la necesidad de la política, determinar el alcance de la misma y su aplicabilidad.
    2. Revisión: con la política documentada, se la remite a un grupo o individuo para su revisión independiente antes de la aprobación final.
    3. Aprobación: se debe obtener apoyo de la administración. La aprobación permite iniciar la implementación de la política.
2. **Fase de implementación**:
    1. Comunicación: consiste en difundir la política, concientizar a los miembros de la organización de la misma.
    2. Cumplimiento: se debe hacer seguimiento del cumplimiento de la misma.
    3. Excepciones: debido a problemas de gestión, no todas las políticas pueden cumplirse de la forma inicialmente planteada. Es por esto por lo que a veces existen excepciones que deben documentarse.
3. **Fase de mantenimiento**:
    1. Concientización: busca que las personas estén cumpliendo la política y entiendan su importancia en la estructura organizativa. Es un trabajo continuo.
    2. Monitoreo: realizar un seguimiento y reportar la efectividad de la política.
    3. Garantía de cumplimiento: identifica omisiones a la política para luego de un análisis de sus causas, intentar prevenir que sigan ocurriendo.
    4. Mantenimiento: la política es contingencial.
4. **Fase de eliminación**:
    1. Retiro: después de que la política haya cumplido con su finalidad y no es necesaria (por ejemplo, por grandes avances tecnológicos) debe ser retirada.



3.6. Clasificación y tipos de ataques contra sistemas de información.

Se denomina **delito informático a toda acción culpable realizada por un ser humano, que cause perjuicio a otras personas** sin que necesariamente se beneficie el autor o que, por el contrario, produzca un beneficio ilícito al autor, **aunque no perjudique de forma directa o indirecta a la víctima, tipificado por la ley, que se realiza en un entorno informático y está sancionado con una pena**.

Un ataque no es más que la realización de una amenaza. Las cuatro categorías generales de amenazas o ataques son las siguientes:

- **Interrupción**: un recurso del sistema es destruido o se vuelve no disponible. Este es un ataque contra la **disponibilidad**. Ejemplos de este ataque son la destrucción de un elemento hardware, como un disco duro, cortar una línea de comunicación o deshabilitar el sistema de gestión de ficheros.
- **Intercepción**: una entidad no autorizada consigue acceso a un recurso. Este es un ataque contra la **confidencialidad**. La entidad no autorizada podría ser una persona, un programa o un ordenador. Ejemplos de este ataque son pinchar una línea para hacerse con datos que circulen por la red y la copia ilícita de ficheros o programas (intercepción de datos), o bien la lectura de las cabeceras de paquetes para desvelar la identidad de uno o más de los usuarios implicados en la comunicación observada ilegalmente (intercepción de identidad).
- **Modificación**: una entidad no autorizada no solo consigue acceder a un recurso, sino que es capaz de manipularlo. Este es un ataque contra la **integridad**. Ejemplos de este ataque son el cambio de valores en un archivo de datos, alterar un programa para que funcione de forma diferente y modificar el contenido de mensajes que están siendo transferidos por la red.
- **Fabricación**: una entidad no autorizada inserta objetos falsificados en el sistema. Este es un ataque contra la **autenticidad**. Ejemplos de este ataque son la inserción de mensajes espurios en una red o añadir registros a un archivo.

Estos ataques se pueden asimismo clasificar de forma útil en términos de ataques pasivos y ataques activos.

- **Ataques pasivos**: En los ataques pasivos el atacante no altera la comunicación, sino que únicamente la escucha o monitoriza, para obtener información que está siendo transmitida. Sus objetivos son la intercepción de datos y el análisis de tráfico. Los ataques pasivos son muy difíciles de detectar, ya que no provocan ninguna alteración de los datos. Sin embargo, es posible evitar su éxito mediante el cifrado de la información y otros mecanismos.
- **Ataques activos**: Estos ataques implican algún tipo de modificación del flujo de datos transmitido o la creación de un falso flujo de datos, pudiendo subdividirse en cuatro categorías:
  - **Suplantación de identidad**: el intruso se hace pasar por una entidad diferente. Normalmente incluye alguna de las otras formas de ataque activo. Por ejemplo, secuencias de autenticación pueden ser capturadas y repetidas, permitiendo a una entidad no autorizada acceder a una serie de recursos privilegiados suplantando a la entidad que posee esos privilegios, como al robar la contraseña de acceso a una cuenta.
  - **Reactuación**: uno o varios mensajes legítimos son capturados y repetidos para producir un efecto no deseado, como por ejemplo ingresar dinero repetidas veces en una cuenta dada.
  - **Modificación de mensajes**: una porción del mensaje legítimo es alterada, o los mensajes son retardados o reordenados, para producir un efecto no autorizado. Por ejemplo, el mensaje "Ingresa un millón de pesos en la cuenta A" podría ser modificado para decir "Ingresa un millón de pesos en la cuenta B".
  - **Degradación fraudulenta del servicio**: impide o inhibe el uso normal o la gestión de recursos informáticos y de comunicaciones. Por ejemplo, el intruso podría suprimir todos los mensajes dirigidos a una determinada entidad o se podría interrumpir el servicio de una red inundándola con mensajes espurios.

4. Auditoría.

Videos

Se trata de una actividad que consiste en:

- **Contenido**: una opinión.
- **Condición**: profesional.
- **Justificación**: sustentada en determinados procedimientos.
- **Objeto**: una determinada información obtenida en un cierto soporte. Es un informe.
- **Finalidad**: determinar si presenta adecuadamente la realidad o esta responde a las expectativas (objetivos de funcionamiento, de rendimiento) que le son atribuidas, es decir, su fiabilidad.

Â»

Definición general: Es la emisión de una opinión **profesional** y **fundamentada** (en procedimientos preestablecidos) sobre una información concreta recogida en un determinado soporte, plasmada en un **informe** cuyo fin es determinar si dicha información **presenta adecuadamente la realidad** o si responde a las expectativas (objetivos de funcionamiento, rendimiento, fiabilidad) que se le atribuyen.

Por ejemplo: un auditor contable opina que el sistema contable auditado tiene un comportamiento aceptable de acuerdo con algo, o de un modo inaceptable de acuerdo con algo (normas, estándares, leyes, etc.).

Hay distintos tipos de auditoría (**naturaleza**): Financiera (evaluar la exactitud de los registros y estados contables), administrativa, de gestión de RRHH (evaluar procedimientos de RRHH, procedimientos de remuneración variable, etc.), de calidad, operativa (evaluar la estructura de control interno en un área determinada, mide y evalúa la eficacia de otros controles) y de sistemas de información.

Una auditoría global involucra tanto a la auditoría contable como a la auditoría operativa. La auditoría de sistemas es parte de la auditoría global.

La auditoría general involucra una auditoría externa e interna. Durante la planificación de la auditoría general debería establecerse una relación entre la actividad de los auditores externos y los internos. De esta forma, se evitan duplicaciones inútiles de esfuerzos y desperdicio de recursos. La coordinación de ambos grupos puede alcanzar una cobertura de auditoría más completa. **Si los controles y procedimientos son buenos, se hará hincapié en las pruebas de cumplimiento. Si por el contrario los controles son débiles o inexistentes, se harán más pruebas sustantivas.**

4.1. Auditoría de sistemas/informática (Lardent)

La auditoría de sistemas de información ha sido definida como la revisión sistemática organizada de los sistemas en funcionamiento para ver si ellos verifican las propiedades de:

- **Vigencia de los objetivos planteados como base del diseño original** (entendiendo por diseño el arreglo o coordinación de las partes o detalle del sistema).
- **Concordancia del sistema con los objetivos (efectividad).** Si está cumpliendo el objetivo básicamente.
- **Permanencia del diseño por no haber sufrido alteraciones que lo degradaran operativamente.** Por ejemplo, que la lógica no esté alterada.
- **Eficiencia del sistema (relación costo-beneficio).**
- **Seguridad del sistema.**

Finalidad: ***evaluar si la operatividad de los sistemas se está realizando en forma efectiva (fiable) y segura según normas establecidas*** (por ejemplo, para asegurar la realización de alguna norma del Banco Central). La información se usa para la toma de decisiones y por ello la información debe ser certera.

La auditoría de sistemas debe asegurar con respecto a los sistemas, lo siguiente:

- La existencia de pistas de auditoría (trazabilidad, para que las operaciones puedan ser rastreadas).
- La existencia de controles adecuados respecto de la entrada de datos y al mantenimiento de la integridad de los mismos, así como también de las transacciones que se efectúan con ellos a través del segmento computarizado del sistema.
- El manejo adecuado de las excepciones y de los rechazos originados por los controles de entrada de datos, y el aseguramiento de su incorporación al sistema en los casos que corresponda.
- El aseguramiento de las políticas corporativas y el cumplimiento de reglamentos gubernamentales que hayan sido incorporados.

- La verificación de que los sistemas se comporten según fueron definidos.
- El aseguramiento de la adecuada interconexión de los sistemas.
- El control de que las modificaciones que se operen sobre los sistemas sean debidamente autorizadas por el nivel jerárquico que corresponda.
- La existencia de condiciones y procedimientos de seguridad que protejan los datos de la organización.

Objeto de audito: recursos informáticos (servidores, computadoras), función de SI (como unidad organizativa, gerencia de sistemas), aplicaciones, proyectos, planes de contingencia, los almacenamientos de datos, etc.

4.1.1. Aspectos a revisar por la auditoría de sistemas (áreas)

- Revisión de controles generales que afectan a la estructura de la organización, a las políticas y procedimientos y al ambiente de control de sistemas de información.
- Revisión de las operaciones de procesamiento de información en el ambiente informático.
- Revisión de seguridad en cuanto a la calidad del acceso lógico, físico y de los controles existentes en el ambiente informático.
- Revisión del software del sistema operativo.
- Revisión de la metodología de desarrollo de sistemas de información.
- Revisión de los controles de software de aplicación.
- Plan de contingencias: que exista y que sea coherente con los objetivos propuestos.

La Auditoría Informática es el proceso de recolección y evaluación de evidencias para determinar cuándo son salvaguardados los activos de los sistemas computarizados, de qué manera se mantiene la integridad de los datos y cómo se logran los objetivos de la organización eficazmente y se usan los recursos consumidos eficientemente. La Auditoría Informática sigue los objetivos tradicionales de la auditoría: aquellos que son de la auditoría externa, de salvaguarda de activos y la integridad de datos, y los objetivos gerenciales, aquellos propios de la auditoría interna que no solo logran los objetivos señalados sino también los de eficiencia y eficacia.

La Auditoría Informática tiene **como objetivo evaluar periódicamente la eficacia, eficiencia e integridad de los sistemas de información, mediante la recolección y análisis de evidencias, y mediante la evaluación de los controles internos implementados, con el fin de verificar si estos salvaguardan los activos, aseguran la integridad de los datos, garantizan el cumplimiento de los objetivos organizacionales y permiten un uso eficiente de los recursos**.

4.2. Control interno.

Se puede definir el control interno como *cualquier actividad o acción realizada manual o automáticamente para prevenir, corregir errores o irregularidades que puedan afectar al funcionamiento de un sistema para cumplir sus objetivos.* Se asemejan a las líneas de defensa.

4.2.1. Categorías de controles (Lardent)

1. **Preventivo:** aquellos diseñados para evitar que se produzca un error, omisión, o actos maliciosos. Ejemplo: control de acceso lógico que permite solamente a personas autorizadas y desde lugares autorizados, acceder a archivos de información sensible.
2. **Correctivo:** corrige errores, omisiones, o actos maliciosos. Ejemplo: campo de fecha que corrige el formato ingresado o la recuperación de un archivo dañado a partir de las copias de seguridad. Busca restablecer el funcionamiento de los sistemas si ocurrió algún daño.
3. **De Detección:** detectan que se ha producido un error, omisión o acto malicioso, e informan de su aparición. Aparece cuando fallan los preventivos. Ejemplo: software de seguridad de acceso a través del cual quedan registradas intenciones de violación de acceso no autorizado.

4.2.2. Implantación de un Sistema de Control Informático Interno (Piattini)

Los controles pueden implantarse a varios niveles diferentes, por ello es importante conocer bien la configuración del sistema (el entorno). Para llegar a conocer la configuración del sistema es necesario documentar los detalles de red, así como los distintos niveles de control y elementos relacionados:

- Entorno de red.
- Configuración del ordenador base.
- Entorno de aplicaciones.
- Productos y herramientas ⟶ decidir qué herramienta es una medida de control interno.
- Seguridad del ordenador base.

Para la implantación de un sistema de controles internos informáticos habrá luego que conocer la configuración del ambiente informático y luego definir:

- **Gestión de sistemas de información**: políticas, pautas y normas técnicas que sirvan de base para el diseño y la implantación de los sistemas de información y de los controles correspondientes.
- **Administración de sistemas**: controles sobre la actividad de los centros de datos y otras funciones de apoyo al sistema, incluyendo la administración de las redes.
- **Seguridad**: incluye las tres clases de controles fundamentales implantados en el software del sistema: integridad del sistema, confidencialidad (control de acceso) y disponibilidad.
- **Gestión del cambio**: separación de las pruebas y la producción a nivel de software y controles de procedimientos para la migración de programas software aprobados y probados. Hay garantías de que el diseño original del sistema se mantiene y los cambios no lo afectan en su esencia. La medida de control interno es cómo voy autorizando los cambios.

La implantación de una política y cultura sobre la seguridad requiere que sea realizada por fases y esté respaldada por la Dirección. Cada función juega un papel importante en las distintas etapas:

- **Dirección de Sistemas de Información (SI)**: Han de definir la política y/o directrices para los sistemas de información en base a las exigencias del negocio, que podrán ser internas o externas.
- **Dirección de Informática**: Ha de definir las normas de funcionamiento del entorno informático y de cada una de las funciones de Informática mediante la creación y publicación de procedimientos, estándares, metodología y normas aplicables a todas las áreas de Informática.

- **Control Interno Informático**: Define los controles periódicos a realizar en cada una de las funciones informáticas.
- **Auditor interno/externo informático**: Ha de revisar los diferentes controles internos definidos en cada una de las funciones informáticas y el cumplimiento de normativa interna y externa.

La creación de un sistema de control informático es una responsabilidad de la Gerencia y un punto destacable de la política en el entorno informático.



4.2.3. Auditoría informática vs. Control Interno Informático (Piattini)

La auditoría informática:

- Tiene la función de vigilancia y evaluación mediante dictámenes, y todas sus metodologías van encaminadas a esta función.
- Tiene sus propios objetivos distintos a los auditores de cuentas, aunque necesarios para que estos puedan utilizar la información de sus sistemas para sus evaluaciones financieras y operativas. Evalúan eficiencia, costo y seguridad en su amplia visión, esto es, todos los riesgos informáticos, ya sean los clásicos (confidencialidad, integridad y disponibilidad), o los costos y los jurídicos, dado que ya no hay una clara separación en la mayoría de los casos.
- Operan según el plan auditor.
- Utilizan metodologías de evaluación del tipo cualitativo con la característica de las pruebas de auditorías.
- Establecen planes quinquenales como ciclos completos.
- Sistemas de evaluación de repetición de la auditoría por nivel de exposición del área auditada y el resultado de la última auditoría de esta área.
- La función de soporte informático de todos los auditores (opcionalmente), aunque dejando claro que no se debe pensar con esto que la auditoría informática consiste en esto solamente.

Control Interno Informático

- Tiene funciones propias (administración de la seguridad lógica, etc.).
- Funciones de control dual con otros departamentos.
- Función normativa y del cumplimiento del marco jurídico.
- Operan según procedimientos de control en los que se ven involucrados y que luego se desarrollarán.
- Al igual que en la auditoría y de forma opcional pueden ser el soporte informático de control interno no informático.

Â»

El Control Interno vive en el "día a día", monitorizando y ajustando los controles.

La Auditoría Informática llega luego, toma muestras y emite un dictamen sobre si todo funcionó según lo planificado.

4.3. Control interno informático (Piattini)

Como unidad organizativa: ***Es el departamento, dirección, etc. que se crea para controlar diariamente que todas las actividades de los SI/TI sean realizadas cumpliendo los procedimientos, estándares y normas fijados por la dirección de la organización y/o la dirección informática, así como con los requerimientos legales*** (Piattini).

Misión (finalidad): asegurarse de que las medidas implementadas por cada responsable sean correctas y válidas. Es decir, se están cumpliendo.

Objetivos (como unidad organizativa):

- Colaborar con las auditorías informáticas tanto internas como externas. El área le provee el principal insumo.
- Controlar que todas las actividades se efectúan de acuerdo con los procedimientos y normas fijados.
- Asesorar sobre el conocimiento y aplicación de las normas, así como asesorar y transmitir.
- Intervenir en la definición, implementación y ejecución de mecanismos y controles para comprobar el logro de los niveles de servicios adecuados (no es solo responsabilidad del CII (interno)).
- Realizar sobre los diferentes SI y entornos informáticos el control de actividades operativas como:
  - Cumplimiento de procedimientos, normas y controles (cambios de versiones de software).
  - Controles sobre la producción diaria.
  - Controles de calidad y eficiencia en el desarrollo y mantenimiento de software.
  - Controles sobre redes y software de base.
  - Controles sobre la seguridad informática.
  - Controles sobre las licencias y relaciones contractuales de los esquemas de outsourcing.

Los controles han de ser al menos completos, simples, fiables, revisables, adecuados y rentables. Respecto a esto último, habrá que analizar el coste-riesgo de su implantación.

Para asegurar la integridad, disponibilidad y eficacia de los sistemas se requieren complejos mecanismos de control, la mayoría de los cuales son automáticos.

Por ejemplo, tener un control de que los operarios de Agunsa no se pasan las contraseñas, un mecanismo de control de que se dejan los dispositivos en un lugar previsto.

4.3.1. Similitudes y diferencias entre control interno informático y auditor informático interno.

Similitudes: Ambos poseen personal especializado en TI. Se realiza una verificación del cumplimiento de controles internos, normativa y procedimientos establecidos por la Dirección de Informática y la Dirección General para los sistemas de información.

Diferencias:

- Control interno informático: Realiza análisis de los controles en el día a día, informa a la dirección del Departamento de Informática, solo se lo realiza al personal interno y el alcance de sus funciones es únicamente sobre el Departamento de Informática.
- Auditor informático: Realiza análisis de un momento informático determinado, informa a la dirección general de la organización, se audita al personal interno y/o externo y tiene cobertura sobre todos los componentes de los SI de la organización.

4.4. Etapas de la auditoría.

Las etapas genéricas de la ISACA son:

- Planeación.
- Trabajo de campo y documentación.
- Reporte y seguimiento.

En la materia no se ve una metodología específica de auditoría, pero es importante tener en cuenta:

1. Identificar el **alcance** (*qué* voy a auditar y qué no, describo los objetos de audito) y los **objetivos** (¿*para qué* hago la auditoría, hay degradaciones? ¿O evaluación porque hace poco fue implementado?) de la auditoría informática, es decir, del objeto a estudiar.
2. Realizar el **estudio inicial** del entorno a auditar (acá debería identificar los controles claves). Se hace para reducir riesgo inherente, identificar fuentes, etc.
3. Ejecución del **programa de revisión** (acá entra la metodología específica).
4. Cierre de la **revisión**. Junto todos los informes y miro los hallazgos.
5. Realizar **informe final**.
6. **Seguimiento** (las recomendaciones y ver si las medidas fueron adoptadas y la efectividad que tuvieron).

Para establecer el área o aplicación a auditar se deben establecer criterios y prioridades que identifiquen el orden en que se auditarán las diversas áreas. Esto está muy influenciado por el impacto en el negocio de las áreas auditadas, el nivel de activos controlados por el sistema, la dimensión de la aplicación, el impacto sobre la toma de decisiones, etc.

4.5. Programa de revisión

El **programa de auditoría** es un conjunto de instrucciones que guía a los auxiliares involucrados en la auditoría y sirve como medio para el control y registro de la ejecución apropiada del trabajo. Dado que los programas de auditoría se preparan anticipadamente en la etapa de planeación, estos pueden ser modificados en la medida en que se ejecute el trabajo, teniendo en cuenta los hechos concretos que se vayan observando.

1. Deriva del plan de auditoría general.
2. Se elabora un programa por cada área de auditoría, o sea, por cada sección a auditar.
3. Detalla:

    1. **La naturaleza, oportunidad y alcance de los procedimientos de auditoría según el plan general de AI.**
    2. **Una descripción de los objetivos de auditoría.**
    3. **Las fuentes de evidencias.**
    4. **El equipo de auditoría.**
    5. **Programa de trabajo específico: Para cada objetivo: pruebas, actividades, hitos de revisión, presentación de informes parciales, tiempo estimado, tiempo real, la referencia de papel de trabajo donde quedó plasmada la ejecución del programa, la rúbrica de quien realizó cada paso y la fecha del mismo.**
    Condiciones o situaciones que requieran toma de decisiones.

4.6. Pasos para la ejecución de una auditoría de sistemas de información.

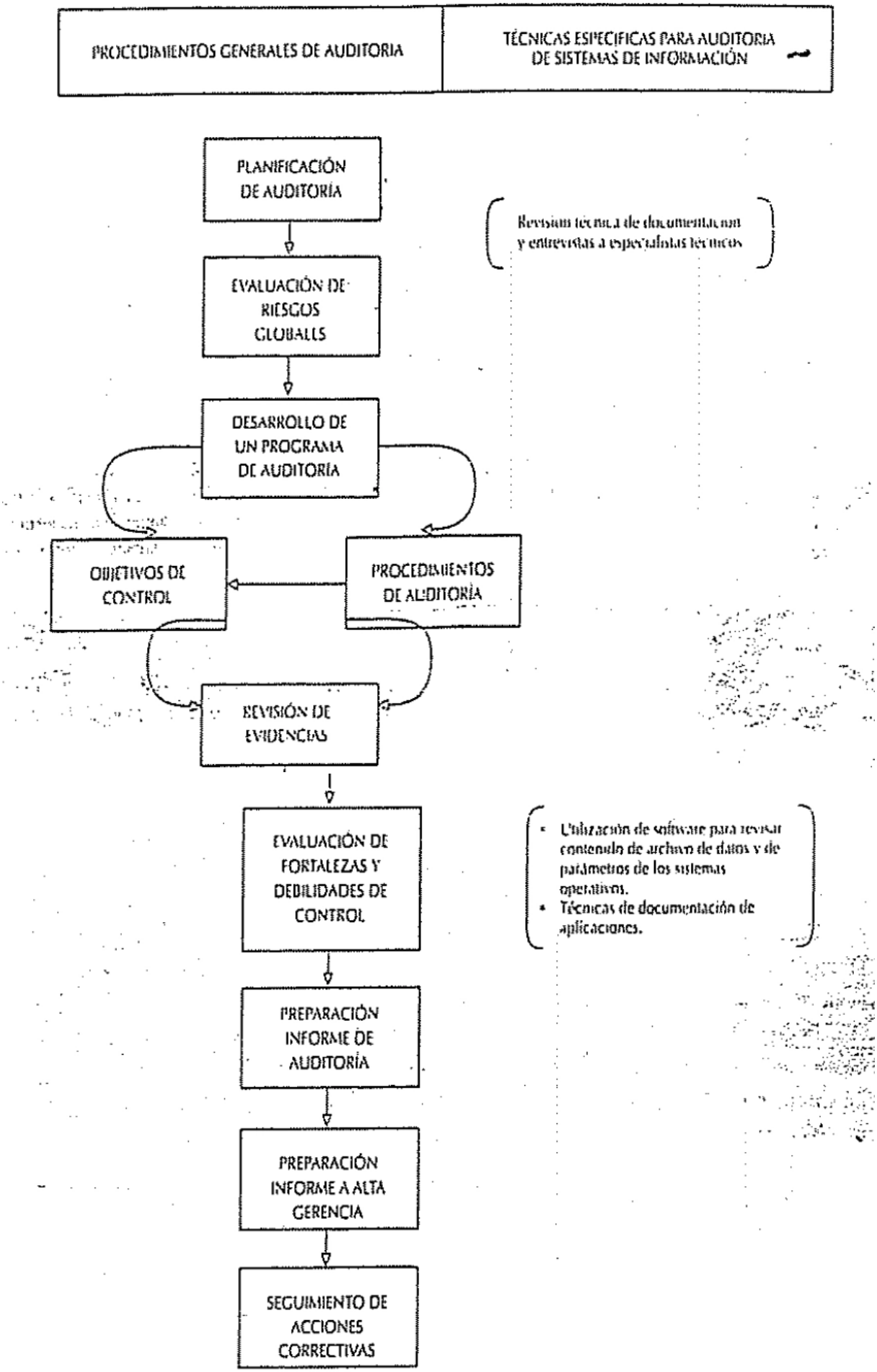


Figura 20-5. Desarrollo de una Auditoría de Sistemas de Información.

4.6.1. Pasos para la ejecución de una auditoría de sistemas de información.

Entre los aspectos que debe considerar el auditor de sistemas de información en el momento de la planificación se encuentran los siguientes:

- **Conocimiento del negocio y su ambiente**: conocer el negocio significa saber qué es lo que se va a revisar y sobre qué se va a opinar. El auditor debe conocer también el ambiente normativo en el que opera el negocio. La información relativa al conocimiento del negocio, relacionada con el procesamiento de datos, se obtiene recorriendo las instalaciones de la organización, manteniendo entrevistas con los gerentes usuarios de la información, con el personal del departamento de sistemas, además de la lectura de planes estratégicos a largo plazo y de todo el material que reúna antecedentes de la organización.
- **Evidencia de auditoría y auditabilidad**: la actividad de Auditoría de SI debe contar con la existencia de fuentes verificables de evidencia de auditoría, que son necesarias para probar los controles o para realizar procedimientos de pruebas de sustanciación.

La planificación de la auditoría incluye:

- Determinar el área o aplicación a auditar: identificar el área que será auditada.
- Definir el objetivo: determinar el objetivo o propósito de la auditoría.
- Establecer el alcance: identificar los sistemas, aplicaciones o módulos que se revisarán para acotar la revisión, así como la duración de la auditoría. El auditor no puede auditar todos los sistemas al mismo tiempo, se deben establecer criterios que faciliten ese ordenamiento.
- Planear los recursos: determinar los recursos necesarios para llevar a cabo la auditoría.

4.6.2. Evaluación de riesgos globales.

En la auditoría, el **riesgo** se refiere a la posibilidad de que la información pueda contener errores materiales (significativos en los estados contables), o bien la posibilidad de que el auditor no detecte errores ocurridos. Los riesgos pueden ser:

- **Riesgo Inherente**: es aquel riesgo de que se produzca un error material debido a la *propia naturaleza de la actividad*. Está fuera de poder ser controlado por el auditor como para poder eliminarlo. Por ejemplo, yo puedo hacer una auditoría de la función informática, pero si la auditoría se dedica al desarrollo yo no soy el indicado, no domino la naturaleza de lo que estoy auditando. Para reducirlo se hace el análisis inicial de la organización.
- **Riesgo de control**: es el riesgo de que un error material no pueda ser evitado o detectado en forma oportuna por *deficiencias en el sistema de control interno*. Está fuera de poder ser controlado por el auditor como para poder eliminarlo, pero sus recomendaciones deben contribuir a reducirlo.
- **Riesgo de detección**: es el riesgo que se corre cuando el auditor realiza *pruebas exitosas a partir de un procedimiento de prueba inadecuado*. Por lo tanto, se puede llegar a la conclusión de que no existen errores cuando, en realidad, los hay. Es del ámbito y tarea exclusiva del auditor.

Estos riesgos también tienen una implicancia material, que significa el señor billetín .

4.6.3. Desarrollo del programa de auditoría

Una vez finalizada la planificación, previa a la ejecución de la auditoría, quedará definido el tema y área a auditar, el objetivo de la auditoría, su alcance (uno o varios sistemas o un espacio de tiempo determinado), las habilidades técnicas y recursos necesarios y la identificación de las fuentes de información para ejecución de pruebas y revisiones. La figura indica los siguientes pasos a desarrollar:

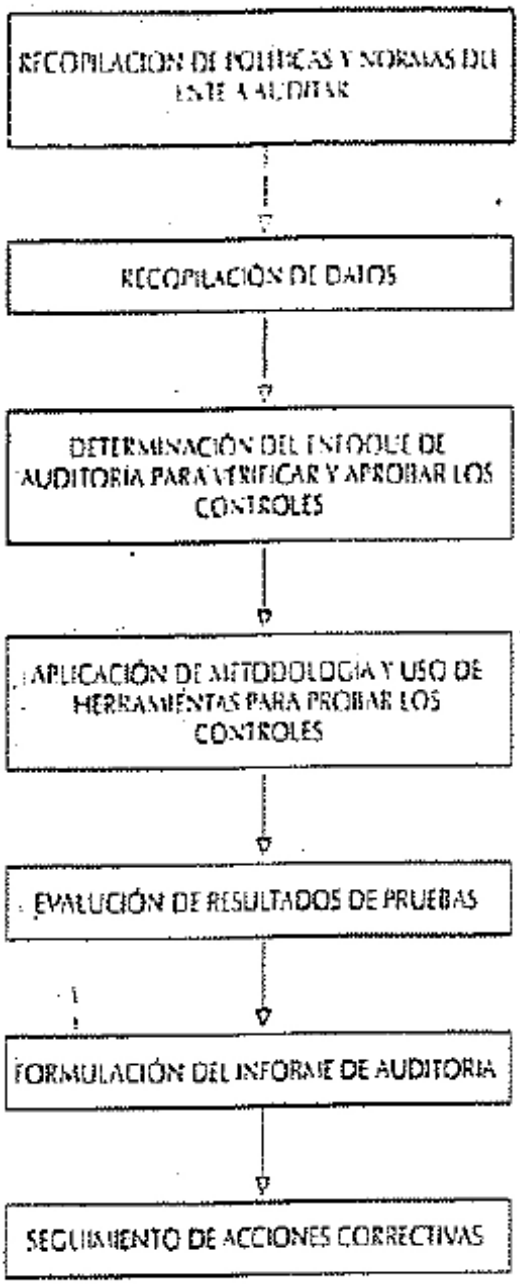


Figura 20-8. Desarrollo del programa de auditoría de sistemas de información.


RECOPILACIÓN DE POLÍTICAS Y NORMAS DEL ENTE A AUDITAR
RECOPILACION DE DATOS
DETERMINACIÓN DEL ENFOQUE DE AUDITORÍA PARA VERIFICAR Y APROBAR LOS CONTROLES
APLICACIÓN DE METODOLOGÍA Y USO DE HERRAMIENTAS PARA PROBAR LOS CONTROLES
EVALUCIÓN DE RESULTADOS DE PRUEBAS
FORMULACIÓN DEL INFORME DE AUDITORÍA
SEGUIMIENTO DE ACCIONES CORRECTIVAS

4.7. La importancia de los procedimientos (Soria Ojeda)

Dentro de la planeación hay que entender la importancia de los procedimientos para garantizar que todo lo que sigo y lo que fundamenta la opinión es lo correcto.

Son el fundamento y a la vez la justificación de la opinión profesional ya que:

- **Son los que proporcionan una seguridad razonable de lo que se afirma** (obtener evidencias y conclusiones). Si hay una receta, razonablemente me va a salir; si le cambio las cosas, ya no.
- **Determinan la trascendencia (impacto) de la auditoría.**

En cuanto a la ejecución de la auditoría, los procedimientos deben establecerse para:

- Planificar y supervisar la auditoría.
- Estudiar y evaluar el control interno.
- Obtener evidencia suficiente y adecuada.

4.8. Evidencia en la auditoría.

El concepto de ***evidencia*** **es definido como el conjunto de información (**todo dato, documento, registro o testimonio**) que ha reunido el auditor, y que dispone para determinar si el ente o los datos auditados han cumplido con los criterios u objetivos de auditoría.**

La evidencia debe reunir condiciones de calidad:

- La evidencia **relevante**, que tiene una relación lógica con los objetivos de la auditoría.
- La evidencia **fiable**, que es válida y objetiva, aunque con nivel de confianza.
- La evidencia **suficiente**, que es de tipo cuantitativo para soportar la opinión profesional del auditor.
- La evidencia **adecuada**, que es de tipo cualitativo para afectar las conclusiones del auditor.

Se debe considerar la confiabilidad de la evidencia en que se apoya el auditor:

- **Evidencia de fuentes externas**: aquella obtenida por fuera de la organización. Es más confiable ya que, en principio, es objetiva.
- **Objetividad**: la evidencia objetiva es más preferible a la que tiene que emitirse un juicio de valor.
- **Calidad de la fuente de evidencia**: la calificación de la confiabilidad de la evidencia depende de las características de quien provee la información.

La evidencia se recopila durante el proceso de auditoría y es el fundamento sobre el cual se formulan las conclusiones. **Las pruebas son el método o proceso mediante el cual se obtiene la evidencia.** Son las acciones realizadas para recopilar información que servirá de base para las conclusiones del auditor. En principio, las pruebas son de cumplimiento o sustantivas.

4.9. Tipos de pruebas

Existen dos categorías de pruebas diferenciadas por la auditoría: las pruebas de cumplimiento y las pruebas sustantivas.

1. **Una prueba de cumplimiento** tiene por objeto ***determinar si los controles que se hacen se ajustan a las políticas y procedimientos de la organización, y si se aplican conforme a la descripción de la documentación de los programas de computación***. Su insumo es la documentación. Ejemplo: verificar que el programa en uso sea la misma versión que las versiones fuente y objeto almacenadas en la biblioteca. Se clasifican en:
    1. **Pruebas de detalles: requieren la revisión de documentos. Es más pasivo.**
    2. **Pruebas de observación e indagación: implica tomar acciones para detectar errores. Son más activas. Por ejemplo: indagar al personal, aplicar programas de revisión de archivos, etc.**
2. **Las pruebas sustantivas** intentan ***verificar la adecuación de los controles existentes para proteger a la organización de las actividades fraudulentas. Le importa cómo se procesa la información.*** Va a indagar, haciendo, por ejemplo, procesamiento en paralelo para ver que los controles que están implementados (manuales y automatizados) son resistentes a intentos de alterar la información. ***Acá pruebo los sistemas***, apunta al tratamiento de la información, ***garantizan que los sistemas hacen lo que tienen que hacer***, acá se usan herramientas informáticas.

4.10. Objetos (secciones de la auditoría de sistemas)

Áreas de la auditoría de SI:

1. Evaluación de la función informática (organización y administración del ambiente informático).
2. Evaluación de los sistemas y procedimientos.
    1. Auditoría del desarrollo de sistemas.
    2. Auditoría de sistemas instalados.
3. Evaluación del proceso de datos, de los sistemas y equipos.
4. Evaluación de la seguridad.
5. Evaluación de los aspectos legales de los sistemas y de la información.

4.11. Deontología (reglas éticas) del auditor

Es el conjunto de principios y reglas éticas que regulan y guían a una actividad profesional.

Estas normas determinan los deberes mínimamente exigibles a los profesionales en el desempeño de su actividad.

Principio de beneficio del auditado: no ir con un prejuicio.

Principio de independencia: asegura que el auditor va a ser objetivo. No puede auditar nada que lo vincule con lo que está auditando. Independencia de criterio. Para la interna tiene que estar garantizado

con la estructura organizativa (deberá depender del gerente), no debe estar involucrado en el área de desarrollo.

4.12. Auditoría interna

Según la relación del auditor con la empresa una auditoría puede ser interna o externa.

Es el examen crítico, sistemático y detallado de un sistema de información de una unidad económica, *realizado por un profesional con vínculos laborales con la misma*, utilizando técnicas determinadas y con el objeto de emitir informes y formular sugerencias para el mejoramiento de la misma. Estos informes son de **circulación interna.**

La auditoría interna es un servicio que reporta al más alto nivel de la dirección de la organización y tiene características de función asesora de control; por tanto, no puede ni debe tener autoridad de línea sobre ningún funcionario de la empresa, a excepción de los que forman parte de la planta de la oficina de auditoría interna, ni debe de algún modo involucrarse o comprometerse con las operaciones de los sistemas de la empresa.

La tarea de la auditoría interna exige una absoluta ***independencia de criterio por parte del auditor***. Esta independencia se consigue por medio de la **estructura organizacional y de la objetividad**. La organización debe estar estructurada de tal manera que la auditoría interna tenga suficiente autoridad como para tomar acción sobre el personal de línea, frente a recomendaciones o hallazgos del auditor. La objetividad se manifiesta mediante la imposibilidad de que el auditor se involucre en el desarrollo e instalación de procedimientos que deberán luego ser evaluados por el mismo implementador. No obstante, el auditor debe participar en la determinación de aquellos **puntos de control** que deben estar incorporados en todo sistema de información.

Objetivo: descubrir *deficiencias o irregularidades* en algunas de las partes de la empresa examinada, y apuntar hacia sus posibles soluciones actuando como auxiliar de la dirección para lograr una administración óptima.

No la puede hacer un personal "jefe de línea". Busca ayudar a la gerencia a ejecutar sus funciones con efectividad.

4.13. Auditoría externa

Es el examen crítico, sistemático y detallado de un sistema de información de una unidad económica, realizado por un profesional *sin vínculos laborales con la misma*, utilizando técnicas determinadas y con el objeto de emitir una opinión independiente sobre la forma como opera el sistema, el control interno del mismo y formular sugerencias para su mejoramiento.

Una auditoría externa se lleva a cabo cuando se tiene la intención de publicar el producto del SI examinado con el fin de acompañar al mismo una opinión independiente que le dé autenticidad y permita a los usuarios de dicha información tomar decisiones confiando en las declaraciones del auditor.

Se reporta a organismos oficiales públicos y/o determinadas empresas. *Tiene implicancias legales*. La periodicidad es puntual. *Está habilitada legalmente para dar fe pública*. Es imprescindible para obtener certificaciones.

Objetivo: ***averiguar la razonabilidad, integridad y autenticidad*** **de los estados, expedientes y documentos y toda aquella información producida por los sistemas de la organización.**

4.14. Comparación entre el control interno, auditoría interna y externa informática.

Control Interno Informático	Auditoría Interna Informática	Auditoría Externa Informática
- Análisis de los controles en el día a día.	- Evaluación de un momento informático determinado.	- Evaluación independiente y objetiva de los sistemas informáticos, llevada a cabo por profesionales externos a la organización, con experiencia en auditoría informática, con un enfoque en la independencia y objetividad.
- Informa a la Dirección del Departamento de Informática.	- Informa a la Dirección General de la organización.	- Alcance: aspectos específicos de la infraestructura informática, como la seguridad, la disponibilidad de los sistemas o el cumplimiento de leyes y regulaciones.
- Solo personal interno.	- Personal interno y/o externo con dependencia de la organización.	
- Alcance: sobre el Departamento de Informática.	- Alcance: tiene cobertura sobre todos los componentes de SI de la organización. Orientada a la mejora continua.	



Comparativa

	Auditoría externa	Auditoría interna
Sujeto	Profesional independiente	Empleado
Objetivo	Examen de los estados financieros, operacionales	Control de operaciones y gestión
Origen del encargo	Obligatoria, legal o estatutaria	Voluntaria
Alcance	Estado de los sistemas de información en su conjunto	Restringida departamento informática
Uso del informe	Empresa y público en general	Restringida a empresa o institución pública
Grado de independencia	Total	Limitada
Responsabilidad	Profesional, civil y penal	Profesional
Continuidad del trabajo	Periódico (habitualmente anual)	Continuo
Intensidad del trabajo	Menor	Mayor

4.15. Informes de auditoría.

El trabajo de auditoría concluye con un informe, su posterior seguimiento, y también con los cursos de acción que debieran surgir debido a las recomendaciones contenidas en el informe. **El informe refleja las conclusiones a las cuales arribó el auditor luego de desarrollar su programa y recopilar las evidencias de auditoría**. El informe de Auditoría Informática es la comunicación del Auditor Informático al cliente, formal, tanto del alcance de la auditoría (objetivos, período de cobertura, naturaleza y extensión del trabajo realizado) como de resultados y conclusiones.

Es momento adecuado de separar lo significativo de lo no significativo debidamente evaluados por su importancia y vinculación con el factor riesgo, tarea eminentemente de carácter profesional y ético, según el entender del Auditor Informático.

Aunque no existe un formato vinculante, sí existen esquemas recomendados con los requisitos mínimos aconsejables respecto a estructura y contenido.

También es cuestión previa decidir si el informe es largo o, por el contrario, corto, por supuesto con otros informes sobre aspectos, como el informe de debilidades del control interno, incluso de hechos o aspectos.

4.15.1. Estructura básica de un informe de auditoría (Lardent)

1. **Introducción: debe incluir los objetivos de la auditoría, el área o funciones abarcadas, el periodo que cubrió la revisión y el alcance o extensión de los procedimientos de auditoría utilizados.**
2. **Descripción de los hallazgos y formulación de recomendaciones: se incluirán las fuentes de evidencia.**

3. **Detalles de las acciones correctivas a desarrollar.**
4. **Opinión del autor sobre la situación encontrada: se refiere a la adecuación de los controles, grado de cumplimiento de los mismos y conclusión sobre los procedimientos que fueron sujetos a revisión. La opinión del auditor debe quedar respaldada en el informe a través de las evidencias recopiladas durante la ejecución de la revisión.**
5. **Anexos: tiene el propósito de mencionar información muy detallada a la que el lector podrá recurrir o no de acuerdo con sus intereses o predisposición. Se trata de detalles que podrán ser importantes pero cuya inclusión en el texto principal puede provocar en el lector la desviación de su atención del tema básico hacia detalles secundarios. Cuando el informe incluye anexos en el texto del mismo deberá hacerse referencia a la información ampliatoria o aclaratoria.**

Â»

Según Soria (mi), primero debería ir la opinión y después los hallazgos.

4.15.2. Tipos de informes (Lardent)

- **Informe sin salvedades:** significa que la revisión de auditoría *no encontró problemas materiales o controles débiles no compensados*. Se expresa que "los estados contables están de acuerdo con principios de contabilidad generalmente aceptados".
- **Informe con salvedades:** *el auditor manifiesta que, si bien los estados contables de la empresa cumplen con las normas de contabilidad generalmente aceptadas, se presenta alguna condición de excepción que debe ser expresamente expuesta.*
- **Informe con opinión adversa:** los estados contables auditados *no cumplen con las normas* contables generalmente aceptadas, o bien, no se compensan los *controles débiles encontrados.*
- **Informe sin opinión:** se emite en los casos en que el alcance de la auditoría es limitado o bien cuando la situación financiera de la organización auditada permite pensar en una posible disolución.

4.16. Auditoría de la Función Informática (Auditoría de Organización y Administración del Ambiente Informático)

La evaluación de la función informática consiste en analizar la organización y administración del ambiente informático de la organización, asegurándose de que los recursos de TI estén bien gestionados, alineados con los objetivos de la empresa, y operando de manera eficiente y efectiva. Área de sistemas.

Las funciones específicas del auditor de sistemas de información deben incluir:

- Tener una comprensión precisa del ambiente informático de la organización por medio de la identificación de las áreas funcionales que procesan información, también oír sus asignaciones y responsabilidades.
- En función de esa comprensión, evaluar la estructura organizacional del ambiente informático y verificar su adecuación a las políticas institucionales.
- Evaluar el ambiente de control de la organización para verificar si se cumplen los objetivos de control que otorgan confiabilidad al procesamiento de información.

- Efectuar pruebas de controles y evaluar sus resultados.
- Detectar las debilidades que puedan existir desde el punto de vista de gestión y del impacto que producen sobre los procedimientos de auditoría. Las debilidades serán una indicación de la necesidad de efectuar más esfuerzos de auditoría en ciertas áreas.

La auditoría de organización propone los siguientes **propósitos**:

- Verificar que la estructura organizativa asegure una adecuada separación de funciones para cumplir con principios de control interno.
- Asegurar la protección de archivos para mantener la continuidad de las operaciones bajo condiciones normales de procesamiento.
- Verificar la presencia de un buen diseño de control interno a causa de acotar las deficiencias y riesgos de procesamiento.
- Verificar que se mantenga un control eficaz en los niveles de autorización de datos y de procedimientos.
- Examinar si existen estándares de actuación y evaluar su adecuación y vigencia.
- Analizar el nivel de formación del personal y evaluar si por medio del mismo se alcanzan los estándares diseñados.

Elementos a auditar:

Evalúa las políticas, la administración, estructura organizativa y aplicación de controles en un ambiente informático; esto incluye:

- Plan de organización: este tiene la división de responsabilidades.
- Segregación de las funciones (en el dpto. de procesamiento de la información).
- Ambiente Informático.

4.17. Auditoría del Desarrollo de Sistemas.

Se audita para mejorar. (Vero)

Lardent: El objetivo de este tipo de auditoría consiste en identificar, analizar y evaluar los requerimientos del usuario, así como también los riesgos, las exposiciones a riesgos y los *controles* que deben ser incorporados a los sistemas de aplicaciones durante las fases de desarrollo. **Verificar que los sistemas se desarrollen siguiendo las metodologías establecidas y que se cumplan con los requisitos del negocio.**

Lo importante es identificar los puntos de control.

Lardent propone la función del auditor como función asesora para ayudar a definir los puntos de control; el problema es después quién hace el control. La persona que después haga la auditoría debe ser alguien distinto al que ayudó a definir los puntos de control.

Se busca contribuir a la calidad y a la confiabilidad del software. La auditoría se puede hacer en 4 niveles:

- Revisión del ciclo de vida: si en el área de desarrollo me dedico a desarrollar. Desarrollo del plan maestro. Evaluación de la factibilidad, que haya una para cada uno de los proyectos. Fases del desarrollo del proyecto (antes de hacerlo hay que saber el framework a utilizar).
- Auditoría de la documentación de sistemas: propone por etapa los documentos que se deben tener.
- Auditoría de adquisición del software: analizar solvencia del proveedor. Recuperación del código fuente. Establecer mecanismo de recupero del código fuente (quién es el propietario). Documentación de respaldo. Nivel de satisfacción de otros clientes. Capacidad de actualizaciones.
- Auditoría de modificación de programas: autorización de cambios. Trazabilidad de los cambios. Documentación de programas y sistemas.

Funciones del Auditor

- Determinar los objetivos y requerimientos básicos de los usuarios del sistema e identificar las áreas afectadas por el mismo.
- Determinar y clasificar los riesgos y exposiciones a riesgos del sistema.
- Procurar la identificación de controles necesarios con el propósito de minimizar los riesgos y exposiciones a riesgos del sistema. Los puntos de control.
- Asesorar a los miembros integrantes del proyecto de desarrollo del sistema respecto de la incorporación de controles en el diseño y de módulos de auditoría, que permitan, una vez implementado el mismo, las revisiones de rutina a través de las pistas de auditoría.
- Asegurar que se sigan los pasos definidos en la metodología de desarrollo aplicada.
- Verificar que se haya efectuado la evaluación de factibilidad y que la misma sea consistente y completa.

Según Piattini: La función auditora es la encargada de comprobar la existencia de procedimientos de control y de verificar su correcta definición y aplicación para determinar las deficiencias que existan al respecto y los **riesgos** asociados a estas carencias de control.

Propone usar la metodología ISACA para evaluar riesgos definiendo objetivos de control. El auditor evalúa el grado en el que se cumple o no esto y para ello hay pruebas asociadas a cada uno de estos criterios (técnicas de control). Para cada cosa a auditar, n objetivos de control, para cada objetivo n técnicas y para cada técnica una o varias pruebas.

- Auditoría de la organización: cómo administra las personas. Propone 8 objetivos de control.
- Auditoría de proyectos: se hace un plan distinto por cada proyecto dependiendo de riesgos, complejidad y recursos.

Comparación entre ambos autores

Piattini sí dice los pasos que hay que hacer, Lardent solo propuestas generales; por lo tanto, es más flexible, el auditor decide en qué punto pone el foco.

Lardent se enfoca más en el marco institucional y organizacional del desarrollo, con una mirada puesta en la productividad, los costos y los aspectos normativos.

Piattini propone un enfoque más estructurado y técnico, centrado en la auditoría detallada del ciclo de vida del desarrollo de sistemas, con herramientas y listas de verificación por cada etapa.

Elementos a auditar:

- Plan Maestro (Plan de SI/TI)
    - Verificar la concordancia del plan, así como de los sistemas que incluye.
- Estudio de factibilidad
- Documentación
- ERS
- Metodología utilizada
- Cada fase del desarrollo del proyecto
    - Definición y análisis de requerimientos
    - Diseño lógico del sistema
    - Diseño físico del sistema
    - Prueba del sistema
    - Implantación
    - Post Instalación (Mantenimiento)

Â»

IMPORTANTE: No confundir auditoría con certificación de calidad; la certificación utiliza la auditoría, pero yo puedo hacer una auditoría para saber si estoy haciendo las cosas bien.

4.18. Auditoría de Sistemas de Aplicación Instalados

Los componentes de los sistemas de aplicación instalados comprenden funciones de captura e ingreso de datos, funciones de procesamiento de esos datos, funciones de almacenamiento y funciones de salida de información.

Es necesario activar controles sobre esas funciones. Los controles intentan asegurar que:

- En un sistema computarizado solamente se ingresen datos completos, exactos, válidos y autorizados (y por única vez).
- La actualización de esos datos se efectúe en los momentos en que realmente corresponda y bajo las mismas condiciones de seguridad arriba señaladas.
- El procesamiento se realice a tiempo y cumpliendo con el diseño aprobado del sistema según sus objetivos.
- Los datos se mantengan protegidos y actualizados.
- Las salidas (resultados del procesamiento) cumplan las expectativas formuladas en el momento de definición del proyecto.

Funciones del Auditor

- Obtener una comprensión profunda de cada aplicación a través del examen de la documentación y de la investigación, con el propósito de identificar los componentes significativos de la misma y el flujo de datos entre los mismos. De ese análisis surgirán las estrategias para el desarrollo de pruebas de auditoría.
- Evaluar los controles incorporados a las aplicaciones para identificar sus fortalezas y debilidades, para definir los objetivos de control.

- Probar los controles existentes para evaluar su funcionalidad, utilizando adecuados procedimientos de auditoría.
- Evaluar el ambiente de control para determinar si se han alcanzado los objetivos del mismo al analizar los resultados de las pruebas.
- Analizar la eficiencia y eficacia de las operaciones que componen la aplicación, comparándolas con estándares de programación y considerando a la tecnología y procedimientos utilizados.
- Verificar el grado de cumplimiento, a través de la aplicación, de los objetivos de la gerencia (formulados en el momento de definición del sistema).

Elementos a auditar:

- Sistemas de entrada y captura de datos.
- Procesos y métodos de procesamiento de datos.
- Control de la salida.

4.19. Auditoría de Seguridad

Tiene como objetivo verificar el funcionamiento correcto, eficaz y eficiente de los sistemas informáticos, prestando especial atención a aspectos como la seguridad física, lógica, de redes, y de los procesos de desarrollo y mantenimiento de los sistemas. Es una rama especializada de la auditoría informática que asegura que los sistemas cumplan con políticas, normas y estándares establecidos para proteger la información crítica de la organización.

Funciones del auditor:

- Evaluar los controles de acceso para garantizar que solo los usuarios autorizados puedan acceder a sistemas y datos sensibles.
- Comprobar la protección contra ataques cibernéticos, como virus, malware y phishing.
- Revisar las políticas de seguridad, protocolos de encriptación y sistemas de respaldo de datos.
- Verificar el cumplimiento de normativas de seguridad (por ejemplo, normas de privacidad de datos, ISO 27001).

Síntesis de los elementos a auditar:

- Controles de acceso a sistemas y datos.
- Protección contra amenazas externas e internas.
- Políticas de seguridad de la información.
- Plan de recuperación ante desastres y copias de seguridad.
- Cumplimiento con normativas de seguridad.

4.19.1. Técnicas de evaluación y auditoría

Al margen de la estrategia seleccionada para la revisión (con o sin computadora), el auditor de sistemas debe desarrollar actividades específicas tales como las que se indican a continuación:

- Verificación de la segregación de funciones.
- Revisión de la documentación de sistemas.

- Un plan de documentación:
  - Definición del problema.
  - Descripción del sistema (análisis y diseño lógico).
  - Descripción de los programas (diseño físico o ingeniería de software).
  - Configuración de registros, diccionarios de datos, esquemas de bases de datos, pantallas e informes.
  - Instrucciones de operación.
  - Descripción de controles.
  - Registro de aceptación.

4.19.2. Cómo se hace el plan de auditoría

1. **Identificás el Alcance y objetivos de auditoría CON RESPECTO AL Objeto:** No puedo empezar si no hago esto. Qué se audita (alcance) y para qué (objetivo), de manera general. Quién me manda a hacer si es externa.
   1. El alcance es hasta dónde llega la evaluación que voy a hacer, qué entra y qué queda afuera, debe quedar claro.
   2. Objetivos es para qué voy a hacer la auditoría. Describo todos los objetos de audito. **Objeto de audito y sujeto son sinónimos**.
2. **Realizar el estudio inicial del entorno a auditar:** Arquitectura, distribución, quiénes son fuentes de evidencia, interlocutores, si hay un control interno como área.
3. **EJECUCIÓN DEL PROGRAMA DE REVISIÓN:** Siguiendo la metodología que corresponda. Desglosamos el alcance y objetivo en partes. Programa de revisión:
   1. Qué es el programa de revisión (*acá va la imagen que nos mandó*): Conjunto de instrucciones, guía a la gente que lleva a cabo la auditoría; una vez que tengo el plan general, esos planes son flexibles y puedo agregar, quitar, postergar. Detallamos alcance, objetivos, objeto de audito para esa parte del todo. ¿Cuántos programas? Dos, porque hay dos áreas.
   2. Fuentes de evidencia: Cuáles son las cosas donde me baso para tener hallazgos. Si yo audito la organización del área informática, una fuente de evidencia puede ser el organigrama, políticas, manual del área.
   3. Equipo de auditoría: Perfiles informáticos que forman parte del grupo. ¿Cuál es el perfil de un auditor informático?: tiene que tener título, habilidades técnicas de seguridad informática, redes, inteligencia artificial, infraestructura, ciberestructura, en derecho informático. Nos sirve conocer los perfiles para saber cómo conformar el equipo.
   4. Por cada objetivo, tenemos una serie de puntos a controlar: responsable, fecha de inicio, puntos de control, condición inicial (tener agendada una reunión, por ej.). El programa de ejemplo es lo más parecido a donde yo plasmo los procedimientos.
   5. Procedimientos: garantiza que el trabajo esté bien hecho. Tipos de pruebas: cumplimiento (documentación, verificar si están los reglamentos, pruebas de detalle y de indagación y observación), y sustantivas (tratamiento de la información, voy a los sistemas y veo cómo operan la información).
4. **Cierre de la revisión:** Estudio sobre las evidencias recolectadas.

5. **Realizar el informe final**: ¿Cuáles son las etapas genéricas de la ISACA? Es una opinión que puede ser favorable (razonablemente), con salvedades (hay que corregir cosas), y una de no conformidades. No hay auditoría sin informe final, se necesita firma.

    1. Planeación: que tiene que ver con los 2 primeros puntos, porque a partir de la revisión inicial planifico;
    2. Trabajo de campo y documentación: salgo a aplicar la planificación; la documentación: tengo que documentar las fuentes de evidencias (algo que se está separando de la norma);
    3. Reporte y seguimiento: reporte es el cierre de la revisión y realización de mi informe. Qué dice mi informe de auditoría: todo lo que se hizo en forma sintética y que apunta directamente a los hallazgos; tengo primero que nada la opinión y los auditores tienen una palabra sobre el funcionamiento del sistema: “razonablemente, bien, o totalmente apartados (de no conformidades)”, luego las recomendaciones que deben ayudar a mejorar.

6. **Seguimiento:** Si se llevaron adelante las recomendaciones, si fueron efectivas y corrigieron las observaciones que tuve. Se hace a través del auditor, uno de los insumos son todos los reportes de auditoría anteriores (para lo anterior, realizar informe, etc.). Si no tengo un impacto social en la organización (en los bancos sí o sí), se tienen auditorías internas, se deben realizar las recomendaciones. Dos dictámenes seguidos con disconformidades, se certifica.

AUDITORÍA
PROGRAMA DE REVISIÓN

01

Definición de la Naturaleza, Oportunidad, Alcance, y según el plan general de AI

- Objeto de audito
- Qué se evaluará de dicho objeto
- Que no se evaluará



02

Descripción de los objetivos de auditoría

¿Para qué se evaluará?
Cada objetivo implicará un procedimiento (secuencia de pruebas y actividades a realizar)



03

Determinar las potenciales fuentes de evidencias



04

Definir el Equipo de auditoría

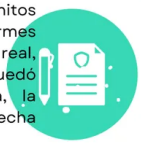
Roles y funciones, y cantidad según naturaleza, alcance y objeto de audito



05

Programa específico

Por cada objetivo: pruebas, actividades, hitos de revisión, presentación de informes parciales, el tiempo estimado, el tiempo real, la referencia al papel de trabajo donde quedó plasmada la ejecución del programa, la rubrica de quien realizó cada paso y la fecha del mismo.
Condiciones o situaciones que requieran toma de decisiones.



Es una opinión profesional, todo un área de especialización de la carrera. La justificación son los procedimientos; impecable debe ser el auditor en la metodología y procedimiento.

La finalidad es ver si esa realidad está respondiendo a esos objetivos de funcionamiento, de rendimiento. Cuán fiable está funcionando ese objeto; lo que auditamos es Objeto de Audito.

Tipo de auditoría:

- Financiera
- Administrativa
- De gestión de recursos humanos, de calidad
- Sistemas de información

El primer video respeta lo que dice Lardent de lo que es la auditoría de los sistemas de información: **revisión sistemática organizada** (tengo una frecuencia, planificación). Aspectos de sistema de información que implica la auditoría de sistemas:

- Para ver si los sistemas de información tienen vigencia por el objetivo planteado como base del diseño original, respecto del diseño original.
- Concordancia del sistema con los objetivos, si es efectivo; si comparo algo con el objetivo, si solo lo cumple, es efectividad. Si me sirve el sistema para lo que tiene que aportarme.
- Permanencia del diseño por no haber sufrido alteraciones que lo degradaran operativamente. Algo interno afecta el funcionamiento del sistema (los alumnos aparecen libres en el Sysacad).
- Eficiencia del sistema: minimizar costos, cuestiones económicas para validar con la auditoría, cómo mantener el sistema. ¿La práctica de desarrollo es eficiente? Que funcione y que su funcionamiento tenga relación costo-beneficio lógica.
- Seguridad del funcionamiento.

Objeto: digo cosas sobre una información en determinado soporte.

Finalidad: determinar si la información es fidedigna, porque se ajusta a la realidad que representa o es fiable.

Cuando audito se amplía el panorama:

- Posible objeto de audito, cualquier cosa que afecte a la información de la organización:
  - Recursos informáticos
  - Función de SI: Unidad organizativa, la gerencia de sistemas debe ser auditada
  - Aplicaciones
  - Proyectos de desarrollo
  - Planes de contingencia
  - Almacenamiento de datos
- Finalidad:
  - Operatividad efectiva y segura según normas establecidas: Los sistemas bancarios, más allá de la normativa del banco, tengo normativa de Banco Central a respetar.

Naturaleza de la auditoría: La nuestra es de los sistemas de información.

- Objeto: recursos informáticos, procesamiento de información, planes de contingencia, manejo del riesgo.
- Finalidad: garantizar que la información que pasa por esos recursos está operando de un modo fiable o seguro. Porque la información es el insumo para la toma de decisiones, no se pueden tomar decisiones no acertadas; una información errónea ya no es información.

Aspectos clave de la auditoría de sistemas:

- Control interno informático: tomamos de Piattini: unidad organizativa, controles dentro del sistema. Que haya controles para garantizar que el proceso se realice con todas las características necesarias.
  - **Como función organizativa**: Tengo que tener dentro de mi área de sistemas un área organizativa, encargada de verificar diariamente que se están realizando las cosas de acuerdo a un estándar establecido (tener validación de que dejan los dispositivos del almacén en lugares previstos). El video (***que nos confundió con Migue***) se refiere a cómo dentro del área organizativa tengo que tener una unidad administrativa desde el concepto que forme parte de la organización.
  - **Misión**: que las medidas implementadas sean correctas y válidas.

Objetivos

- Está en el Piattini.
- Como unidad rescata la colaboración entre personas.
- Realizar sobre los diferentes SI controles como, a nivel interno:
  - Cumplimiento
  - Controles de producción
  - Pautas que se tienen sobre el desarrollo del sistema, calidad del software
  - Controles sobre redes
  - Controles sobre seguridad
  - Controles sobre licencias y relaciones contractuales

Diferencia entre control interno informático y auditor informático

- Ambos son internos, que sea independiente de la gerencia de sistemas, principio fundamental. Debe ser especialista.
- El control interno debe verificar todo el tiempo que las medidas se cumplen, diariamente; el alcance de sus funciones es únicamente sobre el departamento de SI.
- El auditor informático es aquel que, en un determinado momento, realiza esta evaluación. Siempre necesita la estructura de control interno, me la tienen que decir los de control interno.

Como unidad organizativa es Control Interno Informático (CII).

Control interno:

Cualquier actividad que puedo realizar de forma manual o automática para prevenir, corregir errores o irregularidades. Recuerda a las líneas de defensa.

- **Tipos de controles**

  - Preventivos: Para tratar de evitar el hecho, como un software de seguridad que impida los accesos no autorizados al sistema. Prevenir riesgos o errores, los de los usuarios también son errores/amenazas para prevenir. Todo aquello que se piensa para evitar que ocurran cosas no deseadas.
  - Detectivos: Cuando fallan los preventivos, descubrir cuanto antes el evento, impidiendo su avance. Hay una intrusión/algo pasó o se me pasó, tengo que implementar algo que detenga eso, evitar que avance, antes de que termine en algo no deseado.
  - Correctivos: Generalmente orientados a restablecer el funcionamiento de los sistemas si ocurre una irregularidad, tercera línea de defensa, restablecer a la normalidad el funcionamiento. Corregir el error que ya está hecho. Se puede separar en los que corrigen y los que recuperan.

Implantación de Sistema de controles internos:
Para llegar a conocer la configuración del sistema es necesario documentar los detalles de la red, así como los distintos niveles de control y elementos relacionados:

Primer paso: Conocer mi entorno, todos los elementos relacionados. ***Decidir qué herramienta implemento es una medida de control interno, la debo conocer***.

Para la implementación del sistema, tengo una metodología.

Segundo paso, es definir:

- Definir gestión de sistemas.
- Administración de sistemas: base de datos, acceso.
- Seguridad.
- Gestión de los cambios del sistema: ***Si lo veo desde la perspectiva de la auditoría, esto me sirve para que, si llevo una correcta gestión del cambio, puedo tener cierta garantía de que el diseño original del sistema se mantiene y los cambios no afectan a su esencia. Es un elemento metodológico, es una fuente para la auditoría. Tengo que ver cómo voy autorizando los cambios.***

Tipos de auditorías

- Interna: persona que forma parte de la organización y debe tener independencia de criterio, reporta al gerente de sistemas. Lo que ocurre queda dentro de la organización, se reporta a la máxima autoridad, el auditor interno no puede depender del gerente o director de sistemas.
  - Función asesora de control.
  - Pertenece a la empresa, vínculo laboral.
  - No tiene autoridad de línea, solo recomienda, se convierte en autoridad de staff.
  - No se puede involucrar ni comprometer con funciones de la empresa.
  - Es permanente, con la frecuencia y cronograma, es una revisión sistemática.
  - Crítico, sistemático y detallado, con vínculo laboral con la organización. Sus dictámenes quedan para adentro, no está en juego la fe pública.
- Externa: Alguien de afuera, no tiene un vínculo con la organización o el área. Examen crítico sistemático de un sistema de una unidad económica (empresa), que tiene por finalidad ver que los sistemas operan y ver qué aspectos críticos pueden tener impacto en el negocio. La cualidad es

de fe pública. Reporta a organismos oficiales públicos y/o determinadas empresas (cuando hago auditoría de calidad de productos o procesos me viene a auditar un ente certificador).
Características:

- Tiene implicancias legales; si importo mis aplicaciones y están mal, estos pueden denunciar.
- Realizadas por profesionales con certificación.
- Designado auditor por alguien de afuera o entidades externas con auditores definidos, sin vínculo laboral.
- Periodicidad de un momento, puntual.
- Mismo examen de un profesional informático y/o contador público que no tiene vínculos de ningún tipo con la organización, y los reportes tienen fe pública. Sobre el PAMI, ejemplo en el campus. Son de interés público, necesito auditoría externa. No necesariamente es el mismo auditor para el paso del seguimiento.

Comparación entre el control interno, auditoría interna informática y auditoría externa informática

poner foto del cuadro fotooooooooo → pasa mamá Soria

Auditoría externa informática:

- Todos los sistemas y las TI que tengan impacto público.
- ***Lo que tengo que demostrar siendo una organización/empresa al auditor externo es demostrar que cumplo con los 3 aspectos de management seguro de los SI.***

Aspectos procedimentales claves de la auditoría - etapas de la auditoría

Cómo se hace el plan de auditoría:

1. **Identificás el Alcance y objetivos de auditoría CON RESPECTO AL Objeto:** No puedo empezar si no hago esto. Qué se audita (alcance) y para qué (objetivo), de manera general. Quién me manda a hacer si es externa.
    1. El alcance es hasta dónde llega la evaluación que voy a hacer, qué entra y qué queda afuera, debe quedar claro.
    2. Objetivos es para qué voy a hacer la auditoría. Describo todos los objetos de audito. **Objeto de audito y sujeto son sinónimos**.
2. **Realizar el estudio inicial del entorno a auditar:** Arquitectura, distribución, quiénes son fuentes de evidencia, interlocutores, si hay un control interno como área.
3. **EJECUCIÓN DEL PROGRAMA DE REVISIÓN:** Siguiendo la metodología que corresponda. Desglosamos el alcance y objetivo en partes. Programa de revisión:
    1. Qué es el programa de revisión (*acá va la imagen que nos mandó*): Conjunto de instrucciones, guía a la gente que lleva a cabo la auditoría; una vez que tengo el plan general, esos planes son flexibles y puedo agregar, quitar, postergar. Detallamos alcance, objetivos, objeto de audito para esa parte del todo. ¿Cuántos programas? Dos, porque hay dos áreas.
    2. Fuentes de evidencia: Cuáles son las cosas donde me baso para tener hallazgos. Si yo audito la organización del área informática, una fuente de evidencia puede ser el organigrama, políticas, manual del área.

3. Equipo de auditoría: Perfiles informáticos que forman parte del grupo. ¿Cuál es el perfil de un auditor informático?: tiene que tener título, habilidades técnicas de seguridad informática, redes, inteligencia artificial, infraestructura, ciberestructura, en derecho informático. Nos sirve conocer los perfiles para saber cómo conformar el equipo.
4. Por cada objetivo, tenemos una serie de puntos a controlar: responsable, fecha de inicio, puntos de control, condición inicial (tener agendada una reunión, por ej.). El programa de ejemplo es lo más parecido a donde yo plasmo los procedimientos.
5. Procedimientos: garantiza que el trabajo esté bien hecho. Tipos de pruebas: cumplimiento (documentación, verificar si están los reglamentos, pruebas de detalle y de indagación y observación), y sustantivas (tratamiento de la información, voy a los sistemas y veo cómo operan la información).

4. **Cierre de la revisión:** Estudio sobre las evidencias recolectadas.
5. **Realizar el informe final**: ¿Cuáles son las etapas genéricas de la ISACA? Es una opinión que puede ser favorable (razonablemente), con salvedades (hay que corregir cosas), y una de no conformidades. No hay auditoría sin informe final, se necesita firma.

    1. Planeación: que tiene que ver con los 2 primeros puntos, porque a partir de la revisión inicial planifico;
    2. Trabajo de campo y documentación: salgo a aplicar la planificación; la documentación: tengo que documentar las fuentes de evidencias (algo que se está separando de la norma);
    3. Reporte y seguimiento: reporte es el cierre de la revisión y realización de mi informe. Qué dice mi informe de auditoría: todo lo que se hizo en forma sintética y que apunta directamente a los hallazgos; tengo primero que nada la opinión y los auditores tienen una palabra sobre el funcionamiento del sistema: “razonablemente, bien, o totalmente apartados (de no conformidades)”, luego las recomendaciones que deben ayudar a mejorar.

6. **Seguimiento:** Si se llevaron adelante las recomendaciones, si fueron efectivas y corrigieron las observaciones que tuve. Se hace a través del auditor, uno de los insumos son todos los reportes de auditoría anteriores (para lo anterior, realizar informe, etc.). Si no tengo un impacto social en la organización (en los bancos sí o sí), se tienen auditorías internas, se deben realizar las recomendaciones. Dos dictámenes seguidos con disconformidades, se certifica.

Importancia de procedimientos:

- Son el método que yo sigo para garantizar que todo lo que relevo y sobre lo que fundamento la opinión es correcto. Proporcionan una seguridad razonable de lo que se afirma.
- El auditor es una persona procedimental, se ajusta a la metodología/programa de revisión establecido.
- Los procedimientos determinan la trascendencia de la auditoría, qué impacto tiene la auditoría que se realiza. Si hago bien las cosas, ocurren hallazgos, cumplo con la finalidad.

Tipos de prueba

- **Pruebas de cumplimiento**: Determinar si los controles se ajustan a las políticas, y su insumo es la documentación. Entonces, ej., según el organigrama tenemos un área de programación y testing, ¿son personales distintos o multitasking? Si a mí me dice que hay personal distinto, con funciones separadas, debo ver que se cumpla, por eso uso la documentación. Se puede hacer una entrevista

para saber si todos conocen el procedimiento de gestión del cambio, que se cumpla lo definido, lo escrito, patrones definidos. A partir de acá tengo:

  - **Pruebas de cumplimiento de detalles**: Valida un usuario, la condición del alumno. Consiste en la revisión de documentos.
  - **Pruebas de indagación y observación**: la persona conoce el procedimiento de gestión del cambio, entonces vengo un día para ver si realmente sabe cómo actuar. Observar el comportamiento de programas de edición ante situaciones simuladas de generar errores en ingresos de datos.

- **Pruebas sustantivas**: Voy a probar los sistemas, apunta al tratamiento de la información, garantizan que el sistema hace lo que tiene que hacer, que no alteran los resultados. Para proteger la información ante acciones fraudulentas. **Preservar copias de seguridad de datos y ver cómo se hacen (servidor, quiénes tienen acceso) es una prueba sustantiva. Puedo cruzar datos para ver si alguna de las aplicaciones altera las salidas de la otra, usando herramientas informáticas.**

  - Establezco el procesamiento en dos servidores distintos, es un ejemplo, hago un cruzamiento de datos. Que la base de datos esté procesada por ambos servidores y cruzo para ver si tienen los mismos resultados. La app que evalúo y tira resultados contables, en dos servidores con mismo conjunto de datos; si hay diferencia hay un problema.

Objetos (secciones) o áreas de la auditoría informática

Lardent:

- Evaluación de la función informática (organización y administración del ambiente informático): el área de sistemas.
- Evaluación de los sistemas y procedimientos:
  - Auditoría del desarrollo.
  - Auditoría de sistemas instalados (le hago pruebas sustantivas, todo lo que procese información).
- Evaluación del proceso de datos.
- Evaluación de la seguridad: Se audita la seguridad, es un objeto más de audito, ***no son sinónimos auditoría y seguridad***.
- Evaluación de aspectos legales de los sistemas y de la información.

Riesgos del auditor (Etapa inicial)

Riesgo de la auditoría: aunque esté muy formado, como cualquier ejercicio tiene riesgo. Puede entenderse como riesgo de auditoría a la posibilidad de que la información obtenida tenga algún tipo de error o que no se pueda detectar un error que ha ocurrido.

- **Inherente**: Propio de la naturaleza de la actividad, de la organización dentro de la cual están estos sistemas. Generalmente relacionado con la actividad, auditores especializados en diferentes áreas porque tiene que ver con el área, la empresa y actividad realizada. Ejemplo: se puede hacer una auditoría de la función informática, pero si estoy en una empresa de desarrollo de sistemas, la profe no está capacitada porque no sabe nada de desarrollo, muchas cosas asociadas a que no

domina la naturaleza de lo que está auditando. **Hay que tener idea de la empresa y de la actividad a auditar, SIEMPRE, para reducir el riesgo inherente**. Se puede reducir con estudio del objeto de audito.

- **Propios del control**: Cuando hay algo que no está siendo detectado por el sistema de control interno, algo que yo no puedo/se pasó de auditar, porque el mismo sistema de control no lo chequea. Si me doy cuenta es un hallazgo. Cuando el error material no pudo ser evitado o detectado por el sistema de control interno. No tiene medidas de control establecidas, no hay con qué contrastar.
- **Detección**: Cuando se hacen pruebas exitosas, no detectan errores porque los procedimientos son inadecuados. El riesgo que corre el auditor cuando realiza pruebas "exitosas" (no se detectan errores) a partir de procedimientos de prueba inadecuados. Para que me dé cuenta de un procedimiento inadecuado, depende de la calidad del auditor; si no se da cuenta se cumple ese riesgo.
  Otra definición: Peligro que se corre cuando el procedimiento es inadecuado, responsabilidad profesional, relacionado con la materialidad. Cuán rápido el riesgo ocurre, me puede costar económicamente.

El concepto de riesgo está relacionado con el de materialidad, que se refiere a la magnitud del error en términos del impacto potencial para el conjunto de la organización. En general, esa materialidad es expresada en términos monetarios.

Deontología:

- 25 principios deontológicos del auditor:
  - No sesgo, sin opinión adelantada hacia el equipo.
  - De todos los principios, uno importante es el principio de independencia: Independencia de criterio. En auditorías externas es más fácil; en la interna debe estar garantizada por la estructura organizativa, no puede tener una dependencia de la gerencia, no puede tener autoridad lineal del área a la cual sirve, no debe estar debajo del área de control interno. Tampoco puede estar dando vueltas en el área de desarrollo. Qué cosas puedo yo poner en una aplicación que sirvan como pistas de auditoría (contador de transacciones, registros de logs) reiner domado.

¿Por qué auditar desarrollo? Para mejorar; la auditoría es una manera de medir, y midiendo mejoro. Siempre que realizo un proceso de auditoría debo tomar acciones necesarias para solucionar los inconvenientes encontrados; un test es bueno cuando encuentra errores, una auditoría es buena cuando encuentra cosas a mejorar.

- Verificar la conformidad
- Detectar errores
- Mejorar calidad
- Promover mejora
- Responsabilidad y transparencia: qué HU genera esta funcionalidad que genera casos de prueba
- Evaluar cumplimiento de requisitos

La auditoría en el área de desarrollo (Lardent y Piattini):

Lardent: el objetivo es identificar, analizar y evaluar requerimientos, identificando riesgos, la exposición a ellos y cuáles son los controles que se incorporan al área de desarrollo para minimizar.

- IDENTIFICAR puntos de control: el auditor los identifica, indica un conjunto de acciones o actividades generales a diferencia de Piattini.
- La función del auditor es como una función asesora, se genera una discusión de cómo debería ser el auditor. Debo auditar desde el área de desarrollo, y el auditor debe tener una función más asesora para definir puntos de control. Definir o ayudar a armar los puntos de control, ¿quién hace el control después? Propone que el que después haga la auditoría sea una persona distinta a la que define puntos de control:
  - Determinar objetivos
  - Clasificar riesgos a grandes rasgos
  - Identificar controles necesarios
  - Asegurar de que se sigan los pasos propuestos por la metodología de desarrollo
- Cumple un papel activo el auditor, trabaja a la par de las personas que seleccionan procesos. Consultoría en fases de ciclo de vida.
- Lo que se busca es contribuir a la calidad y confiabilidad.
- 4 niveles:
  - Revisión del ciclo de vida:
    - Si en el área de desarrollo produzco software.
    - Partimos del desarrollo del plan maestro: plan de SI/TI, recursos, cronograma y prioridad. Tengo que verificar: su existencia, que esté estructurado para determinar en qué etapa se encuentra cada aplicación, plan flexible por si existen inconvenientes. Son pasos muy generales, no me dice el cómo.
    - Una vez que me aseguro del plan maestro, definimos punto de control para evaluar la factibilidad para cada uno de los proyectos del plan maestro que voy a implementar en los próximos 5 años. Pasos: revisar documentación, si se definieron fechas para empezar a desarrollar, soluciones alternativas al desarrollo, estudio de justificación económica. No me dice el cómo, responsabilidad del auditor.
    - Una vez que definí puntos de control, fases de desarrollo del proyecto: desarrollo propuesto por metodologías clásicas. Para cada etapa, conjunto de actividades. Cap. 25 de Lardent. Dependiendo de la metodología/framework, debo hacer determinadas actividades o no. Si es ágil depende de si me aporta valor. Es más flexible Lardent porque no es tan estructurado.
  - Auditoría de documentación de sistemas:
    - Que cumpla con estándares de la organización: si debo certificar CMMI, debo cumplir con documentación técnica.
    - Propone cosas que debo tener en cuenta por cada etapa mencionada anteriormente.
    - reiner domado.
    - Incluye la posinstalación, mantenimiento.
  - Auditoría de la adquisición de SW:

        * Cuando yo compro el SW a un proveedor externo, analizamos la solvencia de ese proveedor: cuál es su historial económico, qué casos de venta tuvo, qué soporte brinda a partir de la adquisición.
        * Cómo recupero código fuente (enlatado, no hay problema, pero si contrato una persona que desarrolla es necesario definir estos mecanismos, de quién es. Si se rompe la relación, se deja de brindar servicio, ¿qué pasa con ese código? Necesito controlarlo). Cuestiones legales, contractuales. El código fuente es propiedad intelectual, es desarrollo de una persona. Importante para provisión.
        * Documentación de respaldo.
        * Nivel de satisfacción.
        * Capacidad de proveedor para actualizaciones: cómo personalizo producto; si contrato que me desarrollen, cada cuánto me puedo permitir añadir más cosas.
    - Modificación de programas:
        * Poder saber por qué se hizo un cambio, trazabilidad de este cambio.
        * Quién autorizó el cambio.
        * Concordancia entre el programa código fuente y código objeto, lo que tenía antes y lo que tengo ahora.
        * Documentación: lo que sea que me muestre por qué se hizo ese cambio.
        * Documentación de sistemas: manuales de usuario.
        * Todo tiene que estar relacionado, puntos de control que me permitan ver la relación.

Lardent propone áreas que puedo auditar, para cada una de esas áreas establezco puntos de control y dice cuáles actividades se deben seguir para establecerlos; la persona que los establece es distinta a la que los evalúa.

Piattini cap. 22: es muy estructurado, define procedimientos y son claros, no hay agilidad. Métrica v3 es cascada española, metodología de desarrollo definida por Piattini, deriva de ISOs.

Piattini dice que la función auditora (es una función dentro de la empresa) es la encargada de comprobar la existencia de procedimientos de control que me permiten identificar procedimientos de control, verificar la correcta definición y aplicación, determinando sus deficiencias y los riesgos asociados. Propone usar metodología ISACA: evaluar riesgos a partir de riesgos potenciales a los que está sometida una actividad, definiendo objetivos de control; para cada uno defino criterios, la función del auditor es determinar el grado de cumplimiento, Piattini define pruebas asociadas a los criterios determinados. N objetivos de control, técnicas de control asociadas a él (una o varias), para cada técnica pruebas de cumplimiento (una o varias).

- Auditoría de la organización y gestión del área de desarrollo:
    - Desde el punto de vista de las personas y cómo trabajan.
    - Propone ocho objetivos de control, los divide en niveles de la A a la G, el nivel de tecnicismo de cada objetivo de control, están en el libro. La actividad del auditor es más ordenada, tiene una guía clara, al auditor lo ve más como una función asesora.
- Auditoría de proyectos de desarrollo de sistemas de información:
    - El uno no sé.
    - Aprobación, planificación y gestión del proyecto.

Dónde carajo está el Sysacad en este esquema, próx. clase (?.

Niveles de emergencia planteados por Lardent:

- Catástrofe: perdí todo.
- Desastres.
- No desastres.

Hot sites: no tienen infraestructura.

En cuanto a lo que contiene el plan de contingencia, la disponibilidad de las telecomunicaciones y de las redes de energía le agregó Soria.

Taller de Laboratorio asociado: Diseño e implementación de esquemas de líneas preventivas, de detección y recuperación de accesos a recursos sobre la base de un análisis de riesgo para un caso de estudio.

5. Extras

apunte de una clase

5.1. Cuestionario Parte I - Seguridad de SI/TI.

- ¿Qué es el delito informático? ¿Quiénes son los artífices del mismo y con qué modalidad operan?

5.2. Parte II. Auditoría de SI/TI.

1. ¿Qué es la auditoría de sistemas de información?

   La auditoría de sistemas de información es una parte componente de la Auditoría General, y sus funciones integran el plan y los esfuerzos de la misma. La auditoría de sistemas ha sido **definida como la revisión sistemática organizada de los sistemas en funcionamiento para ver si en ellos se verifican las propiedades de:**

   - Vigencia de los objetivos planteados como base del diseño original.
   - Concordancia del sistema con los objetivos (si es efectivo).
   - Permanencia del diseño por no haber sufrido alteraciones que degradaban operativamente.
   - Eficiencia del sistema.

2. ¿Qué es el control interno? Desarrolle las clasificaciones de control. Ejemplifique cada una.

   El control interno comprende el **plan de organización**, **los métodos coordinados y medidas adoptadas** dentro de una empresa para:

   - Salvaguardar sus activos.
   - Verificar confiabilidad y corrección de datos contables.
   - Promover la eficiencia operativa.
   - Fomentar la adhesión a las políticas administrativas.

Clasificación de controles (3 categorías)

Denominación	Descripción	Ejemplo
Preventivo	Diseñados para evitar que se produzca un error, omisión o acto doloso.	Controlar el acceso a la información sensible mediante software, para que solo personas autorizadas puedan entrar a esos archivos.
Correctivo	Corrige errores, omisión o actos dolosos.	Software que pone automáticamente la fecha actual si la fecha ingresada está mal o no se escribió.
De detección	Detectan que se ha producido un error, omisión o acto malicioso e informan de su aparición.	Software de seguridad que guarda un registro cuando alguien intenta entrar sin permiso.

3. ¿Cuáles son los tipos de prueba que se requieren en la Auditoría de SI?

   Hay dos tipos de pruebas:

   - Pruebas de cumplimiento: determinar si los controles se ajustan a las políticas y procedimientos de la organización y si se aplican conforme a la descripción de la documentación de los programas de computación. En pocas palabras: determinar si un control funciona efectivamente y si logra sus objetivos.
   - Pruebas Sustantivas: son pruebas que se hacen para ver si los controles que tiene la organización realmente ayudan a evitar fraudes. Una Auditoría de Sistemas de Información aplicaría una prueba sustantiva para determinar si el inventario de la biblioteca de cintas está registrado adecuadamente.

4. Para cada área de Auditoría determine:

   i. Concepto

   ii. Funciones del Auditor

   iii. Síntesis de los elementos a auditar

Basándome en la información proporcionada en las fuentes, se describen varias áreas de auditoría informática, enfocándose en la seguridad y los procedimientos de sistemas de información. A continuación, se presenta el concepto, las funciones del auditor y los elementos a auditar para cada una de estas áreas según los textos:

1. **Auditoría de Sistemas de Información (Capítulo 20)**:

- **Concepto:** Es un examen independiente de los sistemas de información, procedimientos, operaciones y controles de una organización para determinar si las medidas de seguridad son adecuadas y si se cumplen las políticas y procedimientos establecidos. Su objetivo es identificar, analizar y evaluar los riesgos y exposiciones de los sistemas, identificar problemas y proponer mejoras. La auditoría debe ser objetiva e independiente. Se considera el enfoque, los elementos clave y las tendencias.
- **Funciones del Auditor:** El auditor evalúa, verifica, determina, mide, identifica problemas, recomienda mejoras. Planifica la auditoría. Realiza pruebas. Analiza y documenta los resultados. Se enfoca en la evaluación del control interno, el cumplimiento de políticas, la eficiencia y la eficacia.
- **Elementos a auditar:** Los controles (preventivos, correctivos, de detección), los sistemas, procedimientos y operaciones, los riesgos y exposiciones, la eficiencia y eficacia de los sistemas, los controles en el procesamiento electrónico de datos, los estándares de operatividad, la segregación de funciones, la evidencia de auditoría, los factores que afectan la complejidad (objetivos, evidencia, características de las aplicaciones, controlabilidad, estabilidad, criticidad, técnica), y la documentación relacionada.

2. **Auditoría de Organización y Administración del Ambiente Informático (Capítulo 21)**:

   - **Concepto:** Se centra en evaluar las políticas, la estructura administrativa y las funciones de control dentro del ambiente informático. Busca asegurar que la gestión del ambiente informático apoye los objetivos generales de control de la gerencia. Incluye la revisión de los aspectos lógicos y físicos del ambiente.
   - **Funciones del Auditor:** Evalúa las políticas y la estructura, verifica la segregación de funciones y responsabilidades, asegura el cumplimiento de los principios de control interno, verifica la seguridad del acceso físico, examina la documentación, analiza el nivel de formación del personal. Revisa el plan de organización, las funciones de proyecto y de procesamiento de información. Evalúa los controles de acceso lógico y físico. Verifica la adhesión a estándares.
   - **Elementos a auditar:** Las políticas, la estructura organizativa, la segregación de funciones y asignación de responsabilidades, los principios de control interno, la seguridad del acceso físico, la documentación, el nivel del personal (formación, rotación), las funciones de proyecto, de procesamiento de información y de soporte técnico, los estándares de operatividad, los controles (generales, de aplicación, lógicos, físicos).

3. **Controles de Accesos Lógicos y Físicos (Capítulo 22)**:

   - **Concepto:** El capítulo se basa en el análisis del control interno necesario para salvaguardar la información, enfocándose en la revisión y evaluación de controles de acceso lógico y físico. Se ocupa de cómo se asegura el acceso a los recursos.
   - **Funciones del Auditor:** Verificar el cumplimiento de las políticas de seguridad, evaluar la seguridad del ambiente físico, verificar los controles activos. Revisa las rutas de acceso lógico y físico. Realiza pruebas sobre los controles (ej. contraseñas). Documenta los hallazgos.
   - **Elementos a auditar:** Las políticas de seguridad, la seguridad del ambiente físico (personal, vigilancia, cerraduras, tarjetas de acceso, ubicación de equipos), los controles lógicos activos, las rutas de acceso lógico (centralizado, red de área local, entre computadoras, terminales

remotas, otros dispositivos). Los controles físicos y lógicos por etapas (prevención, detección, recuperación). Los criterios de autorización de usuarios (claves, límites de transacción, límites monetarios), los controles de comunicación, los controles de acceso remoto.

4. **Seguridad en los sistemas de base de datos (Capítulo 23)**:

   - **Concepto:** Examina los controles dentro de los sistemas de base de datos para asegurar la fiabilidad y disponibilidad de un gran volumen de datos. Cubre aspectos como el acceso, las operaciones, el mantenimiento y la seguridad del ambiente de base de datos.
   - **Funciones del Auditor:** Verificar la fiabilidad y disponibilidad del sistema, auditar los controles de acceso (por usuario, por programa), auditar las operaciones y el mantenimiento, auditar la seguridad. Verificar la documentación. Evaluar las funciones y responsabilidades de la administración de base de datos. Revisar los logs. Comprobar los procedimientos de respaldo y recuperación. Verificar la integridad y consistencia de los datos.
   - **Elementos a auditar:** La fiabilidad y disponibilidad del sistema de base de datos, los controles de acceso (por usuario, por programa de aplicación), los controles sobre las operaciones, los controles sobre el mantenimiento, los controles de seguridad. La documentación. Las funciones y responsabilidades de la administración de base de datos. Los logs. Los procedimientos de respaldo y recuperación. La integridad y consistencia de los datos. Las modificaciones a programas.

5. **Seguridad de redes y sistemas distribuidos (Capítulo 24)**:

   - **Concepto**: Examina las medidas de seguridad implementadas en redes y sistemas distribuidos, destacando la complejidad y riesgos asociados a este ambiente. Pone énfasis en la seguridad de las comunicaciones.
   - **Funciones del Auditor:** Revisa los aspectos lógicos y físicos, verifica el cumplimiento de políticas, verifica los perfiles de acceso de usuarios, comprueba la seguridad de los componentes de la red de área local (LAN). Revisa las reglas y controles de transmisión. Verifica la seguridad del acceso remoto. Revisa el hardware y software de comunicación. Evalúa los planes de contingencia.
   - **Elementos a auditar:** La arquitectura o topología de la red (anillo, bus, estrella), los componentes de la red (dispositivos, terminales, cables, software, servidores), la seguridad lógica (políticas, perfiles de acceso, autorización), la seguridad física (cableado, instalaciones), los controles ambientales. Los controles de comunicación (seguridad de transmisión, detección/corrección de errores, identificación de mensajes). La seguridad del acceso remoto. Los planes de contingencia y recuperación. Los protocolos de red (TCP/IP).

6. **Auditoría de sistemas (Capítulo 25)**:

   - **Concepto:** Implica la revisión y evaluación de sistemas específicos, particularmente aquellos que presentan un alto riesgo, son problemáticos o donde el control es difícil. Puede ser parte de una auditoría más amplia de sistemas de información.
   - **Funciones del Auditor:** Revisa y evalúa sistemas, identifica y analiza riesgos y exposiciones, determina y clasifica los riesgos. Propone controles. Verifica el cumplimiento de los

controles y políticas. Evalúa la efectividad de los controles. Planifica la auditoría. Selecciona los sistemas a auditar basándose en riesgos o problemas.
- **Elementos a auditar:** Los sistemas (de aplicación general o específicos), los riesgos y exposiciones asociados, los controles (generales, de aplicación, internos), las políticas, los procedimientos, la documentación, el cumplimiento de políticas y procedimientos.

7. **Auditoría del desarrollo de sistemas (Capítulo 23 en TOC, Capítulo 23 en texto)**:

    - **Concepto:** Consiste en auditar los sistemas a lo largo de su ciclo de desarrollo. El objetivo es asegurar que los sistemas se desarrollen de acuerdo con los requerimientos establecidos y con controles internos adecuados.
    - **Funciones del Auditor:** Participa en la planificación y diseño del sistema, verifica la definición de los requerimientos, evalúa el diseño técnico, lógico y físico, revisa la documentación. Participa en las pruebas (unitarias, de integración, del sistema). Evalúa la implantación y realiza seguimiento. Verifica la metodología utilizada. Evalúa los riesgos asociados al desarrollo.
    - **Elementos a auditar:** La metodología de desarrollo, la definición de requerimientos, el diseño lógico y físico, la documentación (diagramas, diccionarios de datos, etc.), los programas o código, las pruebas (planes, resultados, evidencia), el proceso de implantación, el plan de proyecto, los controles diseñados dentro del sistema.

8. **Auditoría de adquisición de software (Capítulo 26 en texto)**:

    - **Concepto:** Auditoría del proceso mediante el cual una organización adquiere software. Busca asegurar una selección apropiada y términos contractuales adecuados.
    - **Funciones del Auditor:** Revisa el proceso de adquisición, verifica la solvencia y soporte del proveedor, revisa los contratos, examina la documentación, verifica las pruebas y satisfacción del usuario.
    - **Elementos a auditar:** El proceso de adquisición de software, la solvencia y soporte del proveedor, los contratos, la documentación del software, las pruebas y la satisfacción del usuario, las licencias de uso.

9. **Auditoría de modificaciones a programas (Capítulo 26 en texto)**:

    - **Concepto:** Auditoría de los cambios realizados a programas existentes. Asegura que las modificaciones estén autorizadas, documentadas y probadas adecuadamente.
    - **Funciones del Auditor:** Revisa el proceso de modificación, verifica la autorización y documentación de los cambios, comprueba los procedimientos de prueba, verifica el control de bibliotecas de programas (librarian control).
    - **Elementos a auditar:** El proceso de modificación de programas, los registros de autorización, la documentación de los cambios, la evidencia y resultados de las pruebas, el control de bibliotecas de programas, la segregación de funciones en el proceso de modificación.

10. **Auditoría de sistemas instalados de aplicación (Capítulo 26 en texto)**:

    - **Concepto:** Auditoría de los sistemas de aplicación que ya están instalados y en operación. Se enfoca en identificar y evaluar las fortalezas y debilidades de estos sistemas.

- **Funciones del Auditor:** Identifica y evalúa fortalezas y debilidades, verifica la aplicación de controles, evalúa los controles en función de los objetivos. Analiza la eficiencia y verifica el cumplimiento. Realiza pruebas. Revisa los controles de entrada, procesamiento, salida, archivos/base de datos, y las operaciones en distintos ambientes (centralizado, distribuido, en línea, batch). Realiza auditorías específicas de módulos como Compras/Recepción, Cuentas a Pagar, Ventas, Cobranzas, Remuneraciones, Administración de Inventarios, Bienes de Uso.
- **Elementos a auditar:** Los sistemas de aplicación instalados, sus controles (de entrada, procesamiento, salida, de archivos/base de datos) [198, 199-385, detalles exhaustivos en controles de entrada de datos], la integridad y exactitud de los datos, la seguridad de las transacciones, el cumplimiento de los procedimientos, la eficiencia del sistema, los controles de validación de datos.

11. **Auditoría de control de entrada de datos (Dentro del Capítulo 26, página 382)**:

    - **Concepto:** Auditoría de los controles específicos relacionados con la entrada de datos a los sistemas. El objetivo es asegurar la exactitud, integridad, autorización y el cumplimiento de las políticas y procedimientos para los datos que ingresan. Incluye transacciones ingresadas en línea y datos transmitidos a distancia.
    - **Funciones del Auditor:** Verificar la exactitud, integridad y autorización de los datos, verificar la seguridad de las transacciones. Evaluar la eficiencia del sistema. Asegurar el cumplimiento de los procedimientos. Observa las operaciones. Revisa la documentación. Comprueba los procedimientos de validación. Realiza pruebas de entrada de datos remota.
    - **Elementos a auditar:** Los procesos de entrada de datos. Los controles de exactitud, integridad y autorización de los datos. La seguridad de las transacciones. La eficiencia del sistema. El cumplimiento de los procedimientos y políticas. Las reglas y procedimientos de validación de datos. La documentación relacionada. El formato y contenido de los datos. Los registros o logs de transacciones. El control de transacciones en línea y el control de datos transmitidos a distancia.

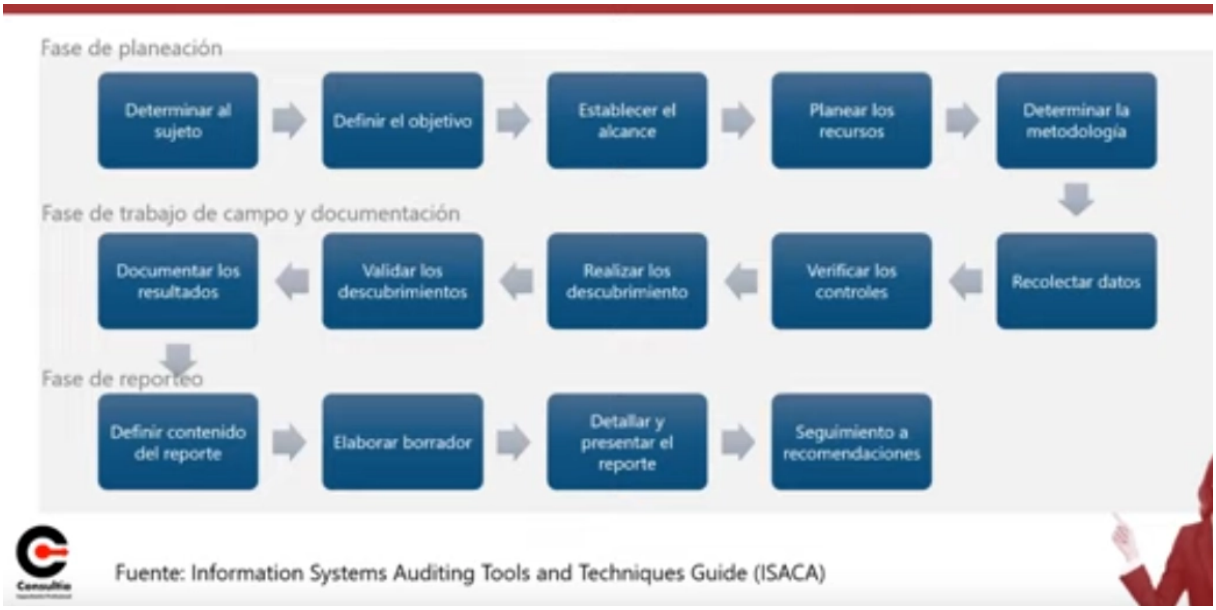
12. Auditoría del desarrollo: efectúe un cuadro comparativo entre el enfoque de Lardent y el de Piattini & Del Peso.

¡Claro! El enfoque de Mario Piattini en cuanto a la **auditoría del desarrollo** de software se centra en varios aspectos clave, basados principalmente en principios de control interno y calidad del proceso de desarrollo. Aquí te dejo un resumen de su enfoque:

✓ **Auditoría como verificación de controles:** Piattini define la auditoría del desarrollo como un proceso de verificación de la existencia y aplicación de procedimientos de control adecuados para garantizar que el desarrollo de los sistemas de información se realice conforme a principios de ingeniería de software robustos.

✓ **Cobertura del ciclo de vida del software:** La auditoría del desarrollo incluye todo el ciclo de vida del software (análisis, diseño, construcción e implantación), pero no considera las fases de explotación, mantenimiento o retirada de servicio.

✓ **Metodología basada en ISACA:** Piattini adopta un enfoque basado en la evaluación de riesgos propuesto por la ISACA. Parte de los riesgos potenciales y define objetivos de control específicos, asociados a técnicas y pruebas de cumplimiento.



fíjense la fuente (ISACA)

✓ **Doble foco:** La auditoría se divide en:

- Auditoría de la organización y gestión del área de desarrollo.
- Auditoría de los proyectos de desarrollo, poniendo especial énfasis en la calidad del desarrollo de los sistemas de información.

✓ **Importancia de la organización:** Piattini recalca que no solo se auditan las tareas técnicas, sino también la gestión organizativa que asegura el éxito de los proyectos.

✓ **Adaptación a la organización y proyecto:** Los objetivos y niveles de cumplimiento no se consideran un modelo cerrado. El auditor debe adaptarlos según las peculiaridades de cada organización y proyecto.

En resumen, el enfoque de Piattini combina la perspectiva técnica y organizativa, y destaca la necesidad de controles de calidad y gestión de riesgos durante todo el ciclo de vida del desarrollo. ¿Quieres que te haga un cuadro resumen o te amplíe algún aspecto?